

به نام آفریدگارِ امنیت و دقت؛

آن‌که خرد را به انسان بخشید تا

با تکیه بر دانشِ هوشمندانه،

تهدیدات را در پیچیدگیِ

شبکه‌ها به دام اندازد و پاسدارِ

حریمِ داده‌ها باشد.





سیستم خبره برای امنیت سایبری

و شکار تهدیدات شبکه

نام و نام خانوادگی

فاطمه کمالی روستا

ارد یبهشت ۱۴۰۰

فهرست

مقدمه ۳

بررسی برخی از حملات و اصطلاحات در حوزه امنیت سایبری ٤

سیستم خبره چیست ۳٦

اجزای سیستم خبره ۳۸

معماری سیستم ٤۲

پایگاه دانش حملات ٤٦

MITRE ATT&CK ٤۷

موتور استنتاج ٤۷

روش های استنتاج ۵۵

شکار تهدیدات ۵۸

تشخیص رفتارهای غیرعادی ٦۲

سیستم هشدار سریع ٦٦

حملات قابل شناسایی ٦۹

نمونه لاگ امنیتی ۷۵

مزایای سیستم ۷۸

محدودیت ها ۸۲

نتیجه گیری ۸٤

واژه‌نامه مفاهیم تخصصی امنیت سایبری ۸۷

مقدمه

امروزه با گسترش اینترنت و دیجیتالی شدن سازمان‌ها، تقریباً تمام اطلاعات، خدمات و ارتباطات بر بستر شبکه انجام می‌شود.

شرکت‌ها، بانک‌ها، بیمارستان‌ها و حتی زیرساخت‌های حیاتی کشورها به سیستم‌های کامپیوتری وابسته هستند. به همین دلیل **Cybersecurity** به یکی از مهم‌ترین حوزه‌های فناوری اطلاعات تبدیل شده است.

در گذشته حملات سایبری ساده‌تر بودند، اما امروزه مهاجمان از روش‌های بسیار پیشرفته‌تری استفاده می‌کنند.

حملاتی مانند:

DDoS Attack : در این حمله تعداد زیادی سیستم آلوده همزمان حجم زیادی **Traffic** به سمت سرور ارسال می‌کنند تا سرور کند شود و سرویس از دسترس خارج شود .

Malware : هر نرم‌افزار مخربی که برای آسیب رساندن یا نفوذ طراحی شده باشد.

Ransomware : نوعی **Malware** که فایل‌های قربانی را **Encrypt** می‌کند و برای بازگرداندن آن‌ها درخواست پول می‌کند.

Brute Force Attack : مهاجم بارها**Password** های مختلف را امتحان می‌کند تا وارد حساب شود.

Network Intrusion : ورود غیرمجاز مهاجم به شبکه یا سیستم‌های سازمان.

Data Breach : دسترسی غیرمجاز یا سرقت اطلاعات حساس.

روزبه‌روز پیچیده‌تر و خطرناک‌تر می‌شوند.

بررسی برخی از حملات و اصطلاحات در حوزه امنیت سایبری

بررسی برخی از حملات مدرن مانند:

Polymorphic Malware :

نوعی بدافزار که مدام کد خودش را تغییر می‌دهد ولی عملکردش ثابت می‌ماند.

یعنی چی؟

- **هر بار اجرا می‌شود شکلش عوض می‌شود**
- **Signatureثابت ندارد**
- **آنتی‌ویروس‌های سنتی را دور می‌زند**

مثال ساده:

یک ویروس که هر بار رمزگذاری (Encryption) و ظاهرش را تغییر می‌دهد، ولی همچنان سیستم را آلوده می‌کند.

Zero-Day Attack :

حمله‌ای که از آسیب‌پذیری ناشناخته استفاده می‌کند.

یعنی چی؟

- **هنوز هیچ Patch یا Fix برای آن وجود ندارد**
- **حتی سازنده نرم‌افزار هم از آن خبر ندارد**

مثال:

یک باگ در Windows که هکرها زودتر از Microsoft پیدا می‌کنند و از آن سوءاستفاده می‌کنند.

Advanced Persistent Threat (APT) :

تهدیدات پیچیده ی ماندگار : این گروه حمله میکند و هیچ **Activity** نشان نمیدهد و میماند . دولت ها پشتش هستند و **Advance** ترین گروه ها هستند.**APT** ها معمولا از **ZeroDay** استفاده میکنند‌از آسیب پذیری استفاده میکند که کسی کتوجه آن نشده یعنی شناخته نشده و خود **Attacker** پیدا کرده.

ویژگی‌ها:

- هدف مشخص (مثلاً یک سازمان یا دولت) : **STUXNET** ص ۹۴
- مدت‌دار (روزها یا ماه‌ها)
- چند مرحله‌ای

مراحل APT

۱. نفوذ اولیه (Initial Access) :

اولین مرحله ورود مهاجم به شبکه یا سیستم قربانی

Phishing Email

ارسال ایمیل جعلی برای فریب کاربر

هدف:

- سرقت **Password**
- اجرای **Malware**
- گرفتن دسترسی اولیه

مثال:

ایمیل جعلی بانک یا شرکت که کاربر را مجبور به کلیک روی لینک مخرب می‌کند.

Malware Attachment

ارسال فایل آلوده به کاربر

فرمت‌های رایج:

- **PDF**
- **Word Document**
- **ZIP File**

مثال:

فایل Invoice آلوده که بعد از باز شدن Backdoor نصب می‌کند.

Exploiting Vulnerabilities

سوءاستفاده از ضعف امنیتی نرم‌افزار یا سیستم

مثال:

- **Exploit*** **روی Windows : استفاده از یک ضعف امنیتی برای نفوذ یا اجرای کد**
- **آسیب‌پذیری Web Server : ضعف امنیتی در وب‌سرور یا برنامه وب**
- **Remote Code Execution*: مهاجم می‌تواند از راه دور روی سیستم قربانی کد اجرا کند**

نتیجه:

اجرای کد مهاجم روی سیستم قربانی

Weak Passwords

استفاده از Password های ساده و قابل حدس

مثال:

- **123456**
- **admin**

- password

روش حمله:

- Brute Force : همه حالت‌ها را تست می‌کند . کندتر ولی قوی
- Credential Stuffing : استفاده از username/password لو رفته از سایت‌های دیگر. چون خیلی از کاربران یک رمز را همه‌جا استفاده می‌کنند.
- Dictionary Attack : سریع‌تر . فقط کلمات رایج را تست می‌کند

VPN Exploits

سوءاستفاده از آسیب‌پذیری‌های VPN برای ورود به شبکه داخلی

چرا خطرناک است؟

چون VPN مستقیماً به شبکه سازمان متصل است.

مثال:

استفاده از Vulnerability * در VPN Server برای دور زدن Authentication

مثال:

مهاجم یک ایمیل جعلی برای کارمند شرکت ارسال می‌کند و کاربر فایل آلوده را باز می‌کند.

۲. تثبیت حضور (Persistence) :

مهاجم تلاش می‌کند حتی بعد از Restart یا Logout همچنان دسترسی خود را حفظ کند.

روش‌ها:

ساخت Backdoor

ایجاد یک مسیر مخفی برای ورود مجدد مهاجم

عملکرد:

مهاجم یک برنامه یا سرویس مخفی نصب می‌کند تا بعداً بدون Authentication عادی وارد سیستم شود.

مثال:

باز کردن یک Port مخفی روی سیستم برای دسترسیRemote

ایجاد User مخفی

ساخت یک Account مخفی با دسترسی بالا

هدف:

دسترسی دائمی حتی اگر Password اصلی تغییر کند.

مثال:

ایجاد User جدید با دسترسیAdministrator

Scheduled Tasks

اجرای خودکار فایل مخرب در زمان مشخص

عملکرد:

بعد از هر Boot یاLogin ، Malwareدوباره اجرا می‌شود.

مثال:

اجرای فایل مخرب هر ۵ دقیقه

Registry Modification

تغییر Registry ویندوز برای اجرای خودکارMalware

چگونه کار می‌کند؟

مهاجم یک مقدار به این مسیرها اضافه می‌کند:

HKCU\Software\Microsoft\Windows\CurrentVersion\Run

یا:

HKLM\Software\Microsoft\Windows\CurrentVersion\Run

هدف:

فعال شدن Malware هنگام Startup سیستم

نصب Malware دائمی

نصب بدافزاری که دائماً در سیستم باقی بماند.

ویژگی‌ها:

- مخفیانه اجرا می‌شود
- ممکن است آنتی‌ویروس را دور بزند
- ارتباط مداوم با مهاجم دارد : (Command & Control یا C&C خیلی مهمه که در Attack ها C&C هکر را پیدا کنیم چون دستورات حمله به C&C داده میشود.)

هدف:

ماندن طولانی‌مدت در سیستم بدون شناسایی

۳. حرکت در شبکه (Lateral Movement) :

بعد از نفوذ، مهاجم در شبکه حرکت می‌کند تا به سیستم‌های مهم‌تر برسد.

کارهایی که انجام می‌دهد:

دسترسی به سرورها

مهاجم سعی می‌کند به Server های مهم شبکه متصل شود.

هدف:

دسترسی به Database

کنترل File Server

دسترسی به اطلاعات حساس

مثال:

ورود به Application Server یاMail Server

سرقتCredential ها

دزدیدن اطلاعات احراز هویت کاربران

موارد هدف:

Username

Password

NTLM Hash : نسخه هش‌شده (Hash) شده Password در سیستم‌های ویندوزی است.

ویندوز معمولاً Password واقعی را مستقیم ذخیره نمی‌کند؛ بلکه مقدار Hash آن را نگه می‌دارد.

اگر مهاجم NTLM Hash را سرقت کند، ممکن است بدون دانستن Password واقعی وارد سیستم شود.

این نوع حمله: Pass-the-Hash نام دارد.

Access Tokens : یک مجوز موقتی است که بعد از Authentication به کاربر داده می‌شود.

این Token نشان می‌دهد:

- کاربر Login کرده
- مجاز به دسترسی است

کاربردAccess Token

وقتی وارد یک سیستم می‌شوی سیستم هر بار Password نمی‌خواهد . از Access Token استفاده می‌کند .

اگر مهاجم Access Token را سرقت کند:

- بدون Password می‌تواند وارد حساب شود

این حمله: Token Hijackingیا Session Hijacking نام دارد.

ابزارهای رایج:

Keylogger

Memory Dump

Credential Dumping

اسکن شبکه

شناسایی سیستم‌ها و سرویس‌های داخل شبکه

اطلاعاتی که جمع‌آوری می‌شود:

IP Addresses

Open Ports

Active Hosts

Running Services

هدف:

پیدا کردن سیستم‌های مهم یا آسیب‌پذیر

دسترسی بهDomain Controller

تلاش برای کنترلActive Directory

اگر مهاجم Domain Controller را کنترل کند:

- می‌تواند به کل شبکه سازمان دسترسی پیدا کند
- Userجدید بسازد
- می‌تواند همهUser ها را مدیریت کند
- Passwordها را تغییر دهد
- به سیستم‌های دیگر نفوذ کند

ابزارهای رایج درLateral Movement

PsExec

ابزار اجرای Remote Command روی سیستم‌های ویندوزی

کاربرد مهاجم: اجرای Command روی سیستم‌های دیگر بدون حضور فیزیکی

Pass-the-Hash

استفاده از Hash رمزعبور به جای Password واقعی

Remote Desktop

Remoteبه سیستم‌های دیگر

کاربرد مهاجم: حرکت بین سیستم‌ها و کنترل آن‌ها

SMB Exploitation

یعنی سوءاستفاده از آسیب‌پذیری‌های پروتکل SMB در سیستم‌های ویندوزی.

SMBپروتکلی در ویندوز است که برای:

- File Sharing
- Printer Sharing

- Network Communication

استفاده می‌شود.

معمولاً روی Port 445 کار می‌کند.

اگر SMB آسیب‌پذیر باشد، مهاجم می‌تواند:

- Remote Code Executionانجام دهد
- وارد سیستم شود
- Malware اجرا کند
- در شبکه حرکت کند (Lateral Movement)

مثال:

استفاده از آسیب‌پذیریEternalBlue

یک Exploit معروف NSA* که از آسیب‌پذیری SMB ویندوز سوءاستفاده می‌کرد.

بعداً این Exploit توسط گروه The Shadow Brokers منتشر شد و در حملات بزرگی استفاده شد.

مهاجم می‌توانست بدون دانستن Password از راه دور وارد سیستم ویندوزی شود و کد مخرب اجرا کند . یعنیRemote Code Execution (RCE)

EternalBlueیک Exploit معروف برای آسیب‌پذیری SMB ویندوز بود که امکان Remote Code Executionرا فراهم می‌کرد و در حملاتی مثل WannaCry استفاده شد.

چرا SMB خطرناک است؟

چون معمولاً:

- داخل شبکه سازمان باز است

- روی تعداد زیادی سیستم فعال است
- برای File Sharing ضروری است

پس مهاجم می‌تواند سریع در شبکه حرکت کند.

Server Message Blockیا SMB در خیلی از شبکه‌ها ضروریه و معمولاً نمی‌شود کامل Port 445را بست، مخصوصاً در:

- Active Directory
- File Server
- Windows Sharing

٤. سرقت داده (Data Exfiltration*) :

مرحله نهایی که مهاجم اطلاعات حساس را از شبکه خارج می‌کند.

داده‌های هدف:

- اطلاعات مالی
- Passwordها
- اطلاعات مشتریان
- اسناد محرمانه

روش‌ها:

Upload به سرور خارجی

ارسال اطلاعات سرقت‌شده به Server مهاجم

مثال:

- FTP Upload

- HTTP Upload
- Remote VPS

خطر:

اطلاعات سازمان مستقیماً از شبکه خارج می‌شود.

Cloud Storage

استفاده از سرویس‌های Cloud برای مخفی کردن سرقت داده

مثال:

- Google Drive
- Dropbox
- OneDrive

چرا خطرناک است؟

چون ترافیک Cloud معمولاً مجاز و عادی به نظر می‌رسد.

Encrypted Channels

ارسال داده‌ها از طریق ارتباط رمزنگاری‌شده

مثال:

- HTTPS
- SSL/TLS
- VPN Tunnel

هدف:

جلوگیری از شناسایی توسط سیستم‌های مانیتورینگ

DNS Tunneling

استفاده از پروتکل DNS برای انتقال داده

مهاجم داده‌ها را داخل DNS Query مخفی می‌کند.

چرا خطرناک است؟

چون DNS معمولاً درFirewall ها مجاز است.

مثال سادهDNS Tunneling به جای DNS عادی:

google.com

مهاجم چیزی شبیه این ارسال می‌کند:

encoded-data.attacker-domain.com

و داده مخفیانه منتقل می‌شود.

پس از بررسی حملات مدرن متوجه این موضوع میشویم که ابزارهای سنتی امنیتی مانند Firewall و Antivirus هنوز نقش مهمی در امنیت شبکه دارند، اما به تنهایی کافی نیستند؛ زیرا بیشتر آن‌ها بر اساس Signature-Based Detectionو الگوهای از قبل شناخته‌شده کار می‌کنند.

در کنار آن‌ها، روش‌های دیگری مانند Anomaly Detectionنیز وجود دارد که رفتار غیرعادی را شناسایی می‌کند، اما این روش‌ها هم محدودیت‌هایی دارند و همیشه قادر به تشخیص حملات پیچیده و جدید نیستند.

Anomaly Detectionفقط "غیرعادی بودن" را تشخیص می‌دهد، اما Expert System با استفاده از قوانین (IF–THEN) می‌تواند نوع دقیق حمله را تشخیص داده و دلیل آن را توضیح دهد.

یعنی اگر یک حمله جدید، Unknown Threatیا رفتار غیرعادی جدید در شبکه اتفاق بیفتد، ممکن است این ابزارها نتوانند آن را تشخیص دهند.

به همین دلیل از Expert System استفاده می‌شود تا با استفاده از Knowledge Base، Inference Engine و Behavior Analysis، تهدیدات و حملات سایبری سریع‌تر و هوشمندتر شناسایی شوند.

به همین دلیل استفاده از سیستم‌های هوشمند در Cybersecurity اهمیت بسیار زیادی پیدا کرده است.

Expert Systemتلاش می‌کند دانش و تجربه متخصصان امنیت را شبیه‌سازی کند.

این سیستم با استفاده از اجزا زیر می‌تواند Threatها و حملات سایبری را شناسایی کرده و Alertهای امنیتی تولید کند.

Knowledge Base :

مخزن اصلی دانش سیستم است.

چه چیزی داخلش هست؟

- قوانین امنیتی (Security Rules)
- الگوهای حملات
- دانش کارشناسان SOC

نقش:

مثل «حافظه متخصص امنیت» عمل می‌کند.

مثال:

- اگر Failed Login زیاد شد ← احتمال Brute Force
- اگر Port زیاد اسکن شد ← احتمالPort Scanning

Security Rules :

قوانین شرطی (IF–THEN) که رفتار حملات را تعریف می‌کنند.

شکل کلی:

IF condition
THEN attack_type

مثال‌ها:

- **IF Failed Login > 10 → Brute Force**
- **IF Ports Accessed High → Port Scan**

نقش:

تبدیل دانش به قوانین قابل اجرا برای سیستم

Inference Engine :

مغز تصمیم‌گیر سیستم

وظیفه:

- **بررسی داده‌های واقعی**
- **مقایسه با Rules**
- **نتیجه‌گیری نهایی**

فرآیند:

۱. **دریافت داده شبکه**
۲. **بررسی Knowledge Base**
۳. **تطبیق Rule**
٤. **تولید نتیجه (Attack / Normal)**

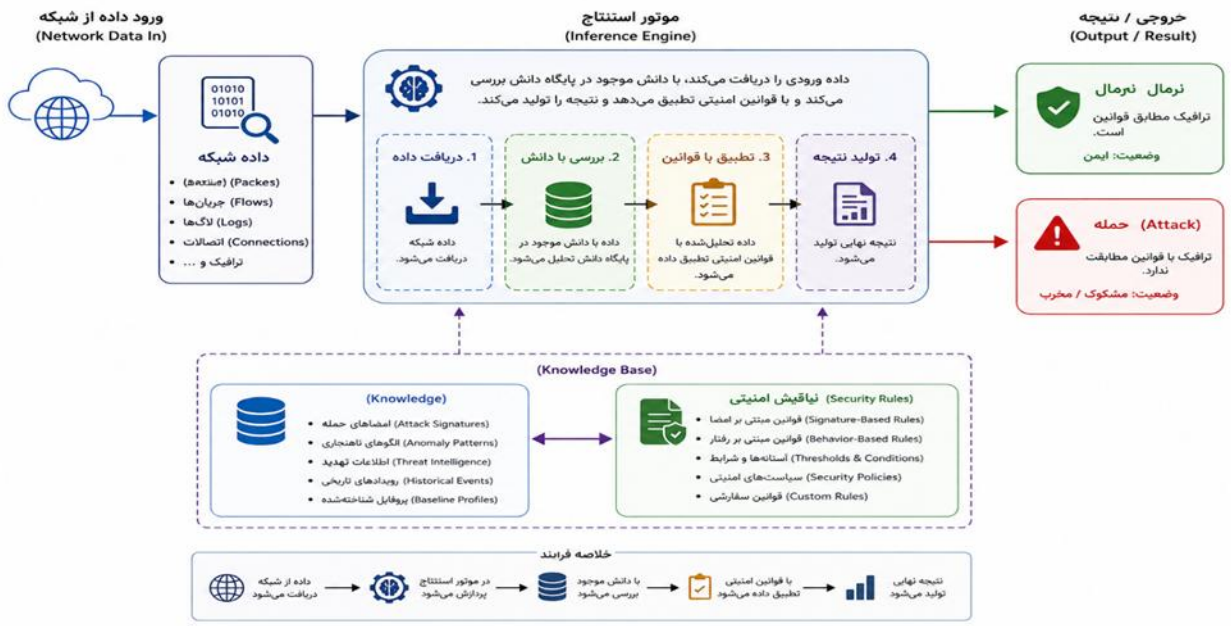
در Zero Day ها میگه Unknown Threat

مثال:

اگر ۱۵ تا Login ناموفق در ۳۰ ثانیه باشد:

Rule → فعال می‌شود

Brute Force Attack → تشخیص داده می‌شود



Network Behavior Analysis :

تحلیل رفتار کلی کاربران و شبکه در طول زمان

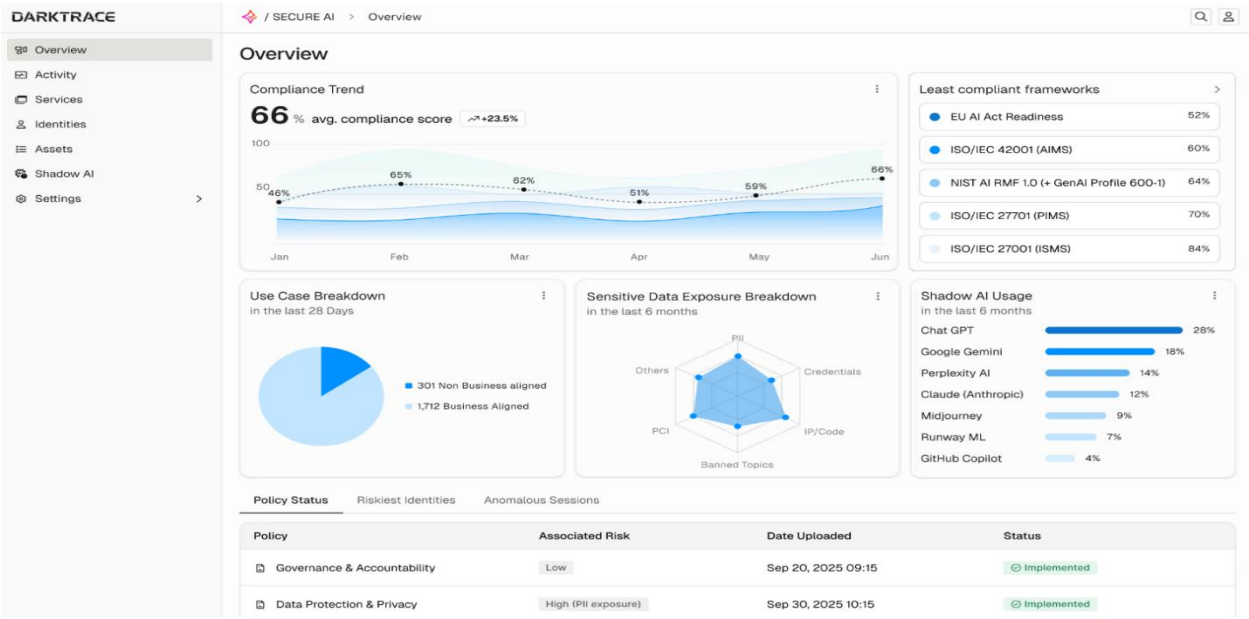
- الگوی ترافیک
- زمان Login ها
- حجم داده ارسالی
- رفتار کاربران

بررسی می‌شود.

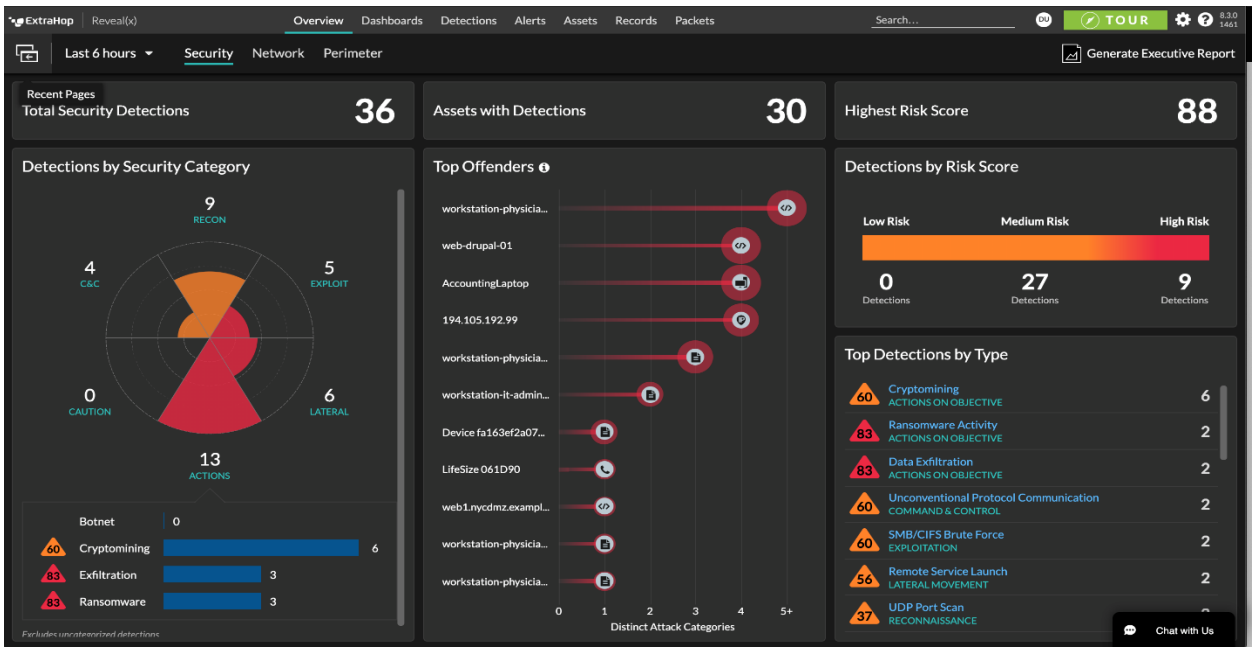
نرم افزارها:

Network Detection & Behavioral Analytics : تشخیص رفتار و حملات پیشرفته

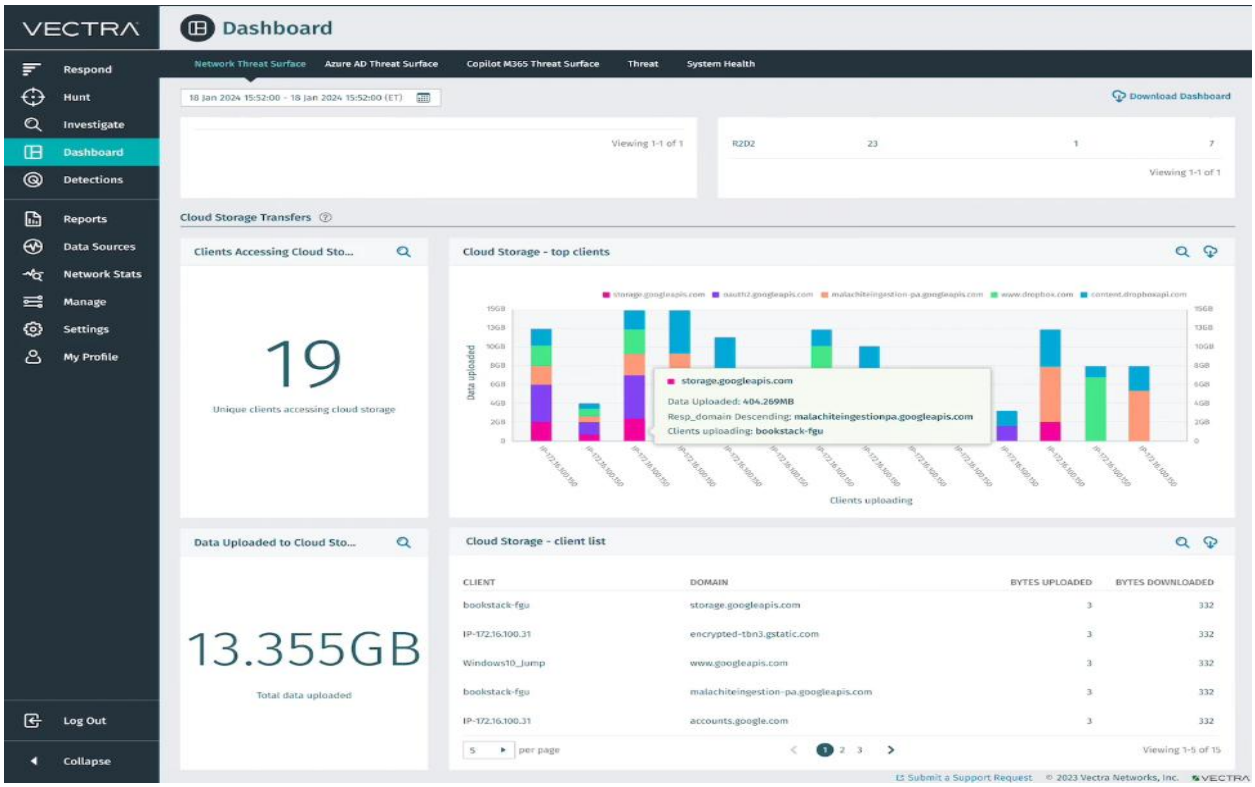
- **Darktrace** : مبتنی بر AI و رفتارشناسی (UEBA) . کشف anomaly بدون rule ثابت



- **ExtraHop Reveal** : تحلیل real-time ترافیک . مناسبenterprise monitoring

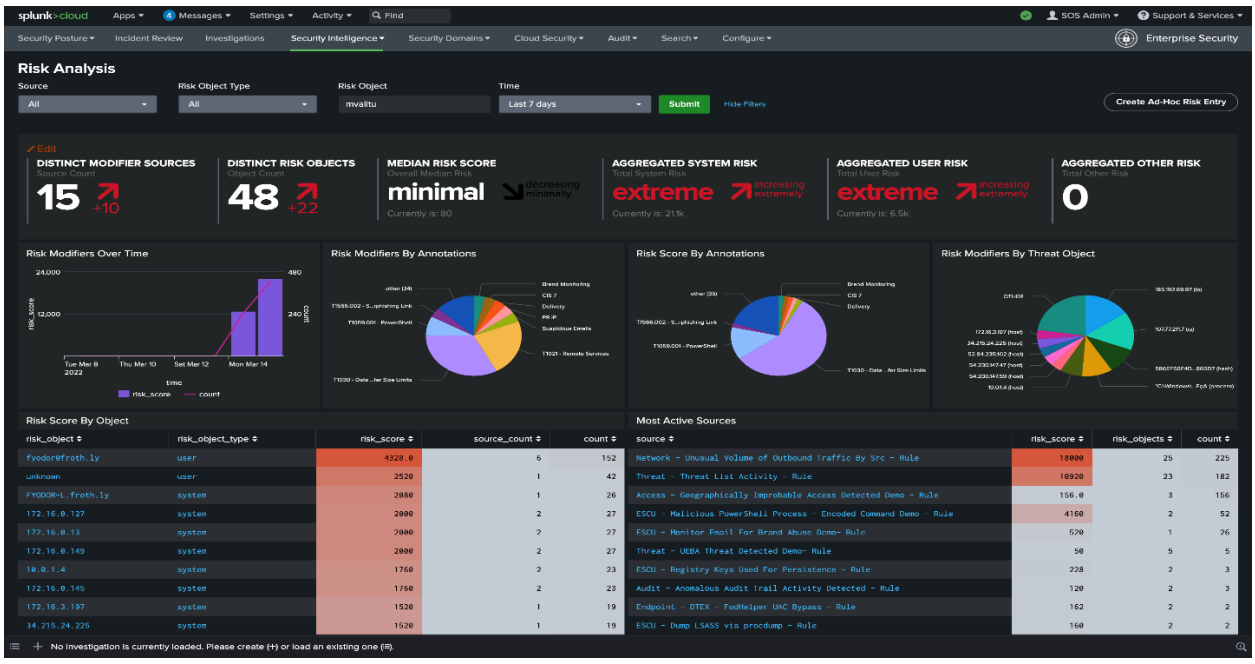


- **Vectra AI** : تمرکز روی حملات داخلی و **lateral movement** .

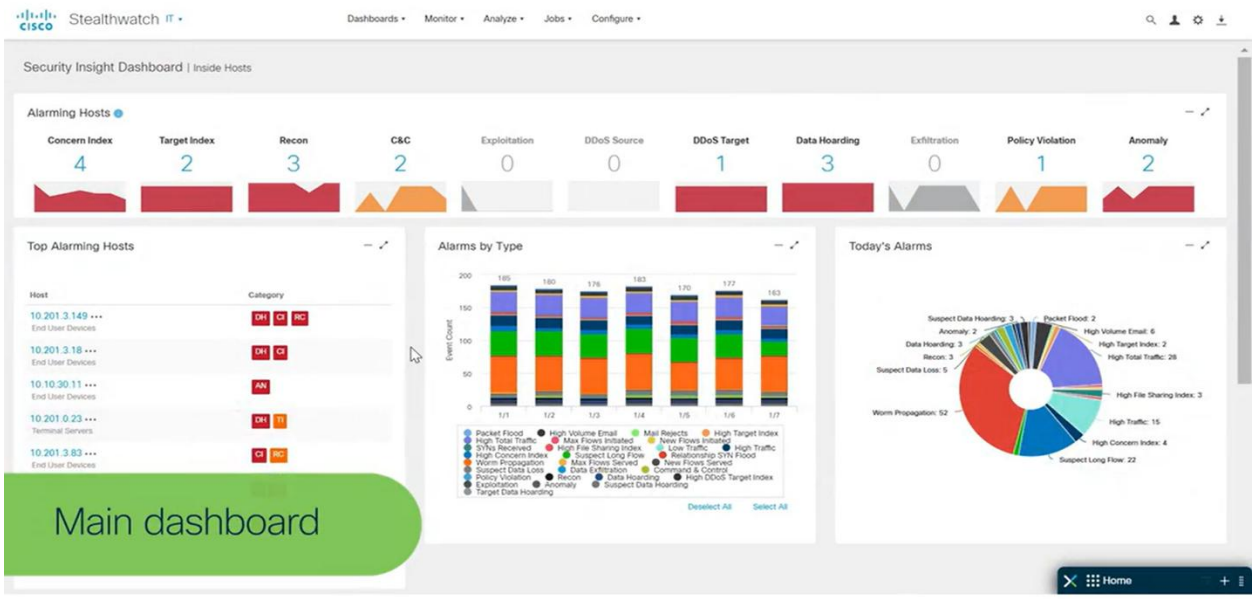


- **Splunk Enterprise Security** : SIEM کامل: **log aggregation + *correlation +**

alerting . بهترین گزینه برای «**Rule-based expert system**»

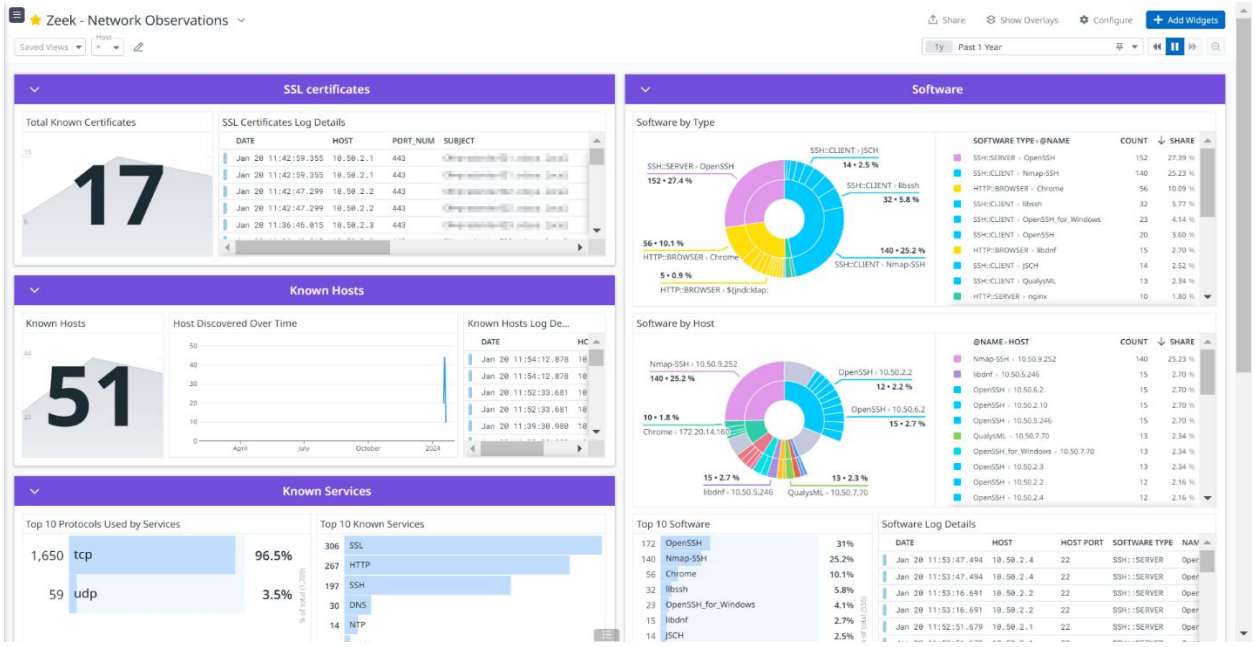


- **Cisco Secure Network Analytics** : تحلیل رفتار شبکه (**flow-based**) . **detection** بر اساس **anomaly** + مدل‌های آماری



Packet / Traffic Analysis : تحلیل بسته‌ها و ترافیک خام

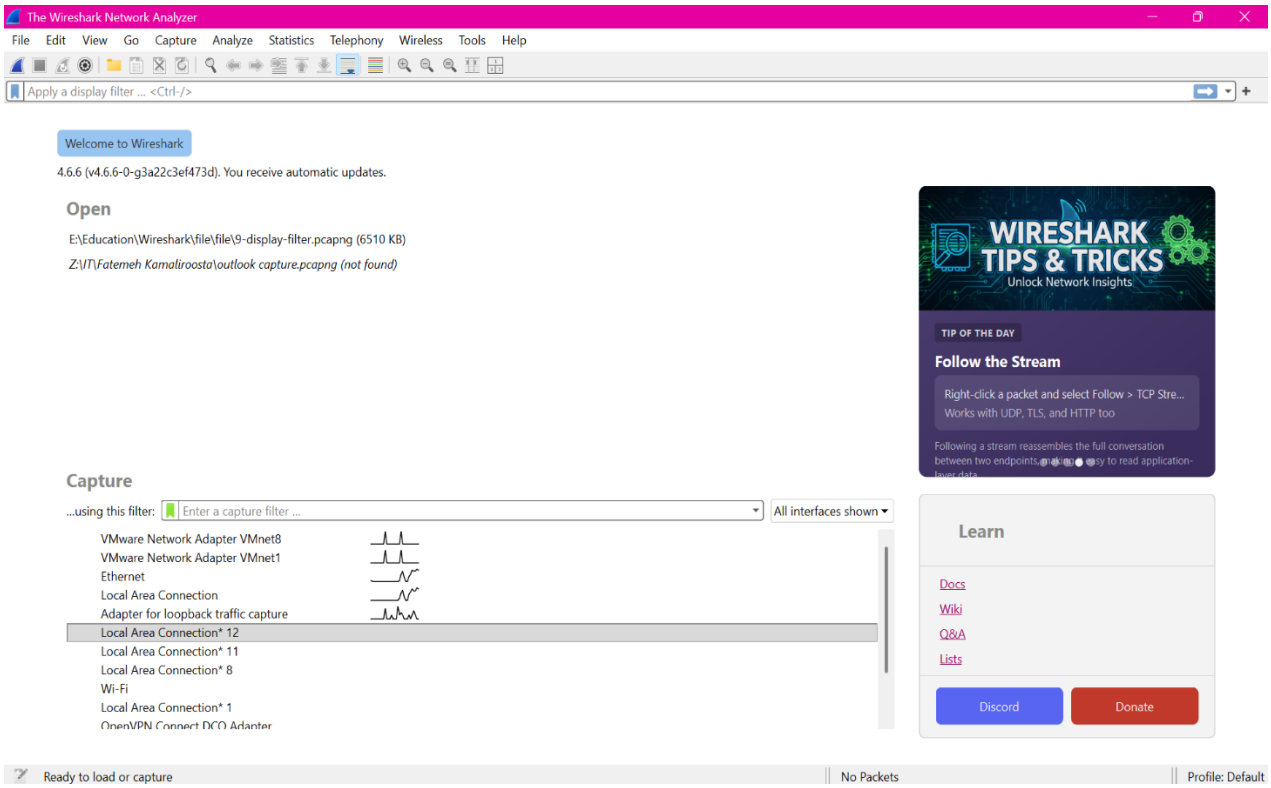
- **Zeek** : تحلیل پروتکل‌ها نه (**signature-based**) . خروجی:**log** های قابل استفاده برای **rule engine**



- **Suricata : signature-based IDS/IPS . تشخیص حملات مثل port scan, malware traffic**



- **Wireshark : تحلیل packet-level . برای debugging و استخراج feature ها**



نقش:

- پیدا کردن رفتار غیرعادی (Anomaly)
- کمک به تشخیص حملات ناشناخته

سوالات

۱.چرا سیستم‌های سنتی کافی نیستند؟

زیرا بیشتر آن‌ها Signature-Based Detection و Static Rule Detection هستند.

یعنی فقط حملات شناخته‌شده را تشخیص می‌دهند.برای مثال آنتی ویروس های signature-base آنتی ویروس هایی هستند که feed هاشون signature های شناخته شده هست.

۲.چرا Expert System مهم است؟

Expert Systemمی‌تواند:

تحلیل منطقی انجام دهد

Behavior Analysisانجام دهد

تصمیم‌گیری امنیتی انجام دهد

حملات ناشناخته را تا حدی تشخیص دهد

به تیم SOC کمک کند

سرعت Threat Detection را افزایش دهد

مثلاً اگر یک User عادی همیشه ساعت ۸ صبح Login کند، اما ناگهان ساعت ۳ بامداد از یک IP ناشناس حجم زیادی Data Transfer انجام دهد، سیستم این رفتار را به عنوان Anomaly Detectionتشخیص می‌دهد.

یا اگر یک IP در مدت کوتاه به تعداد زیادی Port درخواست ارسال کند، سیستم احتمال Port Scanningرا تشخیص می‌دهد.

برای مرور اصطلاحاتی که در این بخش آموختیم به بررسی دو Attack معروف WannaCry و Stuxnet میپردازیم.

WANNACRY

WannaCryیکی از معروف‌ترین و مخرب‌ترین حملات سایبری تاریخ است که در سال ۲۰۱۷ منتشر شد. این بدافزار از نوع:

- Ransomware
- Worm

بود؛ یعنی هم فایل‌های قربانی را رمزگذاری می‌کرد و هم به صورت خودکار در شبکه گسترش پیدا می‌کرد.

برخلاف بسیاری از باج‌افزارهای قدیمی که نیاز به کلیک کاربر یا اجرای فایل توسط قربانی داشتند، WannaCryمی‌توانست بدون دخالت کاربر و به صورت خودکار سیستم‌های دیگر را نیز آلوده کند.

نحوه عملکردWannaCry

این بدافزار ابتدا شبکه را اسکن می‌کرد و سیستم‌هایی را که Port 445 داشتند شناسایی می‌کرد.

Port 445مربوط به پروتکل(SMB (Server Message Block است که برای File Sharing , Printer Sharing و ارتباطات ویندوزی در شبکه استفاده می‌شود.

آسیب‌پذیری اصلی

WannaCryاز آسیب‌پذیری:

MS17-010

در SMBv1 سوءاستفاده می‌کرد.

برای Exploitation این ضعف امنیتی از ابزار EternalBlue استفاده می‌شد.

EternalBlue یک Exploit بود که امکان Remote Code Execution را فراهم می‌کرد.

یعنی مهاجم می‌توانست بدون داشتن Password از راه دور روی سیستم قربانی Command یا Code اجرا کند.

مراحل حمله WannaCry

۱. Network Scanning

بدافزار IP های شبکه را اسکن می‌کرد تا سیستم‌های دارای SMB را پیدا کند.

۲. SMB Exploitation

اگر سیستم Patch نشده بود و SMBv1 فعال داشت Exploit اجرا می‌شد.

۳. Remote Code Execution

پس از موفقیت Exploit ، کد مخرب روی سیستم قربانی اجرا می‌شد.

۴. Payload Installation

بدافزار فایل‌های خود را روی سیستم نصب می‌کرد و Persistence ایجاد می‌کرد تا بعد از Restart نیز فعال بماند.

۵. File Encryption

سپس WannaCry فایل‌های مهم قربانی را Encrypt می‌کرد.

فایل‌هایی مثل:

- Word
- Excel
- PDF

- تصاویر
- Databaseها

هدف قرار می‌گرفتند.

الگوریتم رمزگذاری

WannaCryاز ترکیب AES و RSA استفاده می‌کرد.

ابتدا فایل‌ها با AES رمزگذاری می‌شدند و سپس کلید AES با RSA محافظت می‌شد.

درخواست باج

پس از رمزگذاری فایل‌ها، پیامی نمایش داده می‌شد:

Your files have been encrypted.
Pay Bitcoin to recover your files.

Worm Propagation

خطرناک‌ترین بخش WannaCry قابلیت انتشار خودکار آن بود.

بدافزار پس از آلوده کردن یک سیستم:

- شبکه داخلی را اسکن می‌کرد
- سیستم‌های دیگر را پیدا می‌کرد
- دوباره EternalBlue را اجرا می‌کرد

Lateral Movement

WannaCryبعد از نفوذ اولیه، بین سیستم‌های داخلی شبکه حرکت می‌کرد.

مثلاً:

PC → File Server → Domain Controller

Kill Switch

یکی از عجیب‌ترین بخش‌های WannaCry وجود Kill Switch بود.

داخل کد بدافزار یک Domain عجیب و تصادفی وجود داشت:

iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com

بدافزار قبل از شروع حمله تلاش می‌کرد به این Domain متصل شود.

منطق داخلی بدافزار تقریباً به این شکل بود:

If Domain Reachable:
Stop Execution

If Domain Unreachable:
Continue Attack

در ابتدا این Domain ثبت نشده بود، بنابراین درخواست بدافزار Fail می‌شد و WannaCry حمله را ادامه می‌داد.

بعداً محقق امنیتی:

هنگام تحلیل Malware متوجه این Domain شد و آن را ثبت (Register) کرد.

بعد از ثبتDomain ، درخواست‌های بدافزار پاسخ دریافت می‌کردند و WannaCry طبق منطق داخلی خودش اجرای Malware را متوقف می‌کرد.

به همین دلیل انتشار نسخه‌ای از WannaCry کاهش پیدا کرد و این مکانیزم به نامKill Switch شناخته شد.

دلیل اینکه چنین مکانیزمی داخل Malware بود احتمالاً برای تشخیص:

- *Sandbox Detection
- Anti-Analysis Technique

استفاده شده بود.

یعنی Malware تلاش می‌کرد تشخیص دهد آیا داخل محیط تحلیل امنیتی اجرا شده یا خیر.

Indicators of Compromise (IOC)

رفتارهایی که سیستم‌های امنیتی برای تشخیص WannaCry بررسی می‌کردند:

IOC
افزایش SMB Traffic
اتصال‌های زیاد به Port 445
File Encryption Activity
Unusual Process Creation
Rapid Lateral Movement

ارتباط با Expert System

سیستم خبره می‌تواند چنین رفتارهایی را تشخیص دهد.

مثلاً Rule زیر:

IF Multiple SMB Connections Detected
AND Rapid File Changes Observed
AND Port 445 Activity is High
THEN Possible WannaCry Attack

تشخیص مبتنی بر Anomaly

سیستم همچنین می‌تواند رفتارهای غیرعادی زیر را تشخیص دهد:

- افزایش ناگهانی SMB Traffic

- اسکن تعداد زیاد IP
- رمزگذاری سریع فایل‌ها
- ارتباط غیرعادی بین سیستم‌ها

نمونه لاگ امنیتی

[CRITICAL ALERT]
Possible WannaCry Activity Detected

Host: PC-12
Protocol: SMB
Port: 445

Detected Behaviors:
- Rapid SMB Scanning
- File Encryption Activity
- Lateral Movement

Risk Level: CRITICAL
Action Taken: Host Quarantined

روش‌های جلوگیری

برای جلوگیری از حملات مشابه WannaCry :

- نصب Security Patch ها
- غیرفعال کردن SMBv1
- محدودسازی Port 445
- استفاده از IDS/IPS
- Network Segmentation

- Backupمنظم
- Endpoint Protection

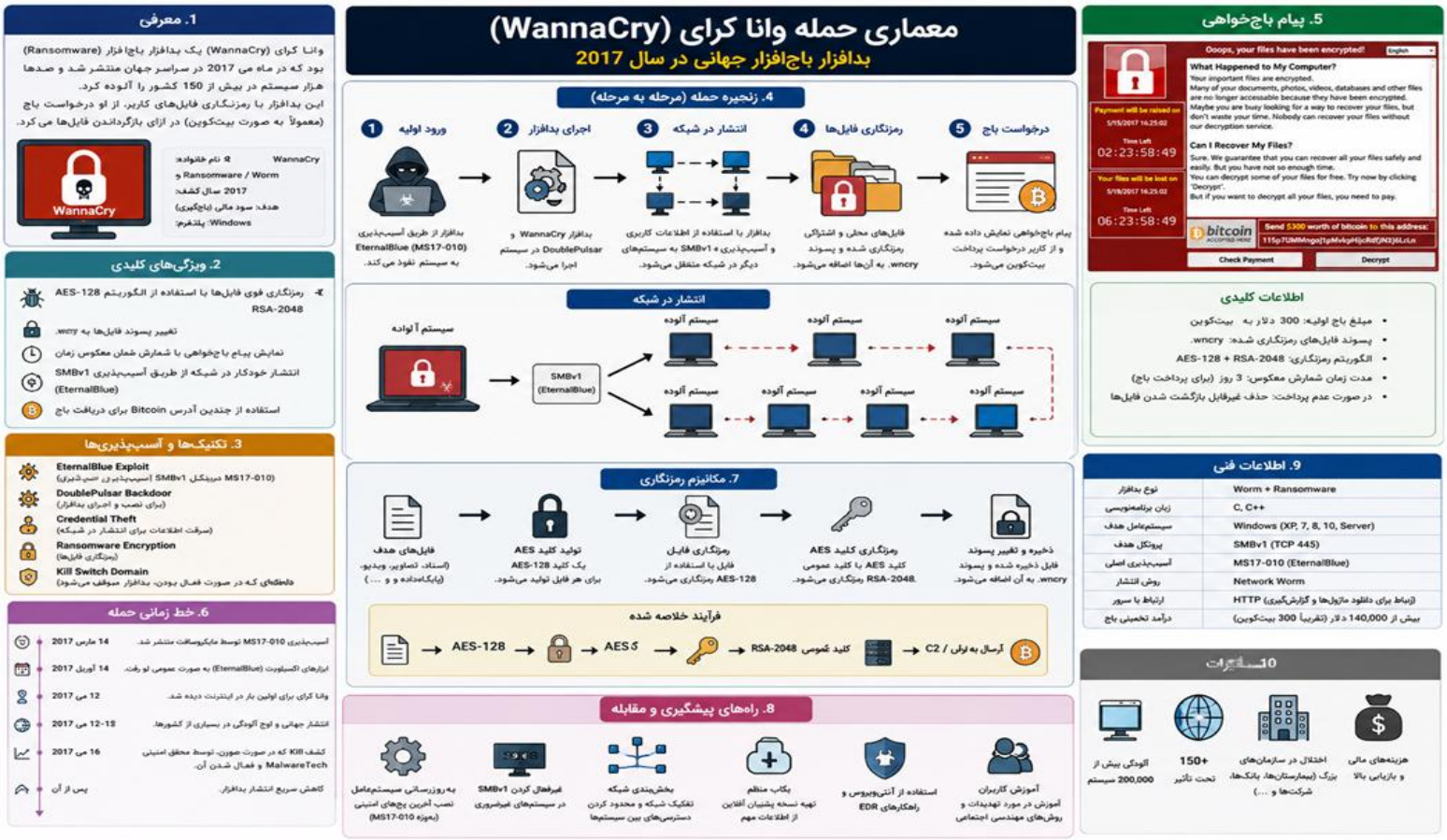
ضروری است.

نتیجه‌گیری

WannaCryنشان داد که ترکیب:

- Ransomware
- Worm Capability
- SMB Exploitation
- Remote Code Execution

می‌تواند باعث ایجاد یک حمله بسیار گسترده و مخرب شود.



STUXNET

یکی از معروف‌ترین و پیچیده‌ترین حملات سایبری تاریخ است و معمولاً به عنوان اولین حمله«سلاح سایبری صنعتی» شناخته می‌شود.

یک بدافزار بسیار پیشرفته بود که حدود سال ۲۰۱۰ کشف شد و هدف اصلی آن تخریب سیستم‌های صنعتی ایران، مخصوصاً تأسیسات هسته‌ای نطنز، بود.

این بدافزار برای حمله به:

- سیستم‌های کنترل صنعتی (ICS)
- سیستم‌های SCADA
- PLCهای شرکت Siemens

طراحی شده بود.

هدف حمله

هدف اصلی:

تخریب سانتریفیوژهای غنی‌سازی اورانیوم بدون ایجاد هشدار واضح برای اپراتورها.

Stuxnetکاری می‌کرد که:

- سرعت چرخش سانتریفیوژها تغییر کند
- تجهیزات به‌مرور آسیب ببینند
- در عین حال مانیتورینگ سیستم وضعیت عادی نشان دهد

نحوه عملکردStuxnet

۱.ورود به شبکه

از طریق:

- USBآلوده
- آسیب‌پذیری‌های Zero-Day ویندوز
- شبکه داخلی

چون شبکه هسته‌ای ایران ایزوله (Air-Gapped) بود، USBنقش مهمی داشت.

۲. آلوده کردن ویندوز

Stuxnetچندین آسیب‌پذیری ناشناخته ویندوز را Exploit می‌کرد تا:

- دسترسی Administrator بگیرد
- پنهان بماند
- خودش را گسترش دهد

۳.شناسایی PLC هدف

بدافزار بررسی می‌کرد:

- آیا نرم‌افزار Step7 زیمنس نصب است؟
- آیا PLC خاص موردنظر وجود دارد؟

اگر سیستم هدف نبود غیرفعال می‌ماند تا شناسایی نشود .

۴.تغییر منطقPLC

وقتی PLC مناسب پیدا می‌شد:

- کد مخرب داخل PLC, Inject می‌شد
- سرعت موتورهای سانتریفیوژ تغییر می‌کرد
- داده‌های جعلی به مانیتورینگ ارسال می‌شد

چرا Stuxnet مهم است؟

اولین حمله سایبری فیزیکی مشهوربود و Stuxnetنشان داد که بدافزار می‌تواند تجهیزات واقعی صنعتی را نابود کند.

استفاده از چندینZero-Day دیگر دلیل اهمیت Stuxnet هست. این بدافزار از چندین آسیب‌پذیری ناشناخته استفاده می‌کرد که نشان‌دهنده منابع بسیار قوی پشت حمله بود.

Stuxnet یکی از اولین نمونه‌های مشهور جنگ سایبری دولتی بود.بعد ازStuxnet کشورها روی Cyber Warfare* سرمایه‌گذاری بیشتری کردند و امنیت ICS/SCADA اهمیت بسیار بیشتری پیدا کرد .

تکنیک‌های امنیتی مرتبط

تکنیک	توضیح
Privilege Escalation	گرفتن دسترسی بالا
Lateral Movement	حرکت در شبکه
Rootkit	مخفی‌سازی
PLC Code Injection	تزریق کد به کنترلر صنعتی
Zero-Day Exploit	سوءاستفاده از آسیب‌پذیری ناشناخته
Persistence	ماندگاری در سیستم

1.معرفی

استاکنکس (Stuxnet) یک بدافزار صنعتی بسیار پیشرفته بود که در حدود سال 2010 کشف شد. هدف اصلی آن تخریب سانتریفیوژهای غنی‌سازی اورانیوم در تاسیسات نطنز ایران بود. این اولین نمونه شناخته شده از سلاح سایبری است که باعث آسیب فیزیکی به تجهیزات صنعتی شده است.

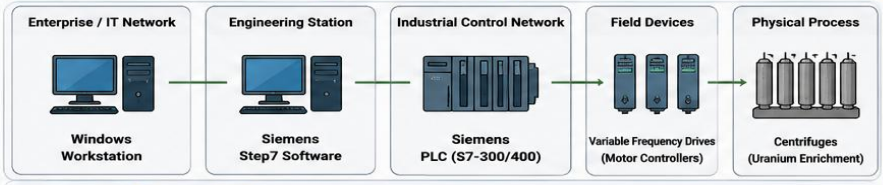
اطلاعات کلی

- **نوع:** اسپیوWorm/Rootkit صنعتی
- **هدف:** تاسیسات هسته‌ای نطنز ایران
- **2010:** سال کشف
- **احتمالاً** توسعه توسط: آمریکا و اسرائیل
- **هدف نهایی:** تخریب سانتریفیوژها بدون جلب توجه اپراتورها

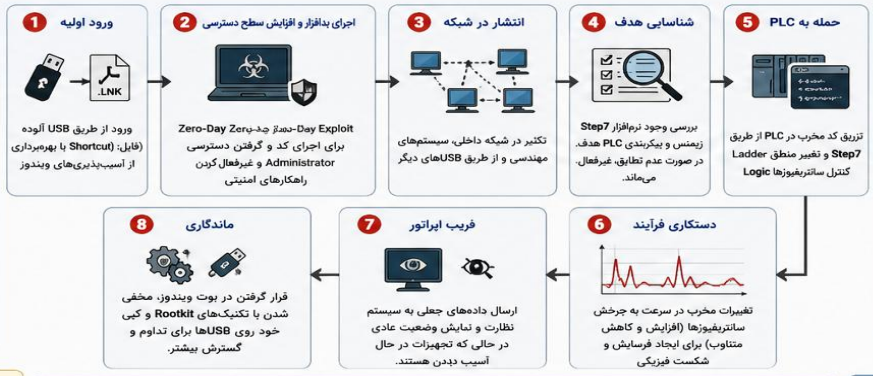
3.آسیب‌پذیری‌ها و تکنیک‌های کلیدی

- Multiple Windows Zero-Day Exploits
- LNK (Shortcut) Vulnerability
- Print Spooler Exploit
- Privilege Escalation
- Rootkit (User-mode & Kernel-mode)
- PLC Code Injection
- Data Spoofing (False Data to HMI)
- Air-Gap Bypass via USB
- Stealth & Evasion Techniques

Stuxnet Attack Architecture
معماری حمله استاکنکس



2 زنجیره حمله (مرحله به مرحله)



4.ویژگی‌های منحصر به فرد استاکنکس

هدف‌گیری دقیق
بدافزار فقط در صورت وجود محیط هدف فعال می‌شد.

مخفی‌سازی پیشرفته
استفاده از Rootkit برای مخفی کردن فایل‌ها، فرآیندها و ارتباطات.

حمله سایبری – فیزیکی
اولین بدافزار شناخته شده که باعث آسیب فیزیکی به تجهیزات صنعتی شد.

استفاده از چندین Zero-Day
استفاده همزمان از چند آسیب‌پذیری ناشناخته ویندوز.

مناسب برای محیط‌های ایزوله
طراحی شده برای کار در شبکه‌های (Air-Gapped) Air-Gapped.

5.تأثیرات

- تخریب هزاران سانتریفیوژ IR-1 در نطنز
- تأخیر چند ساله در برنامه هسته‌ای ایران
- آغاز عصر جنگ سایبری صنعتی
- افزایش شدید توجه به امنیت ICS/SCADA

6.خط زمانی رویدادها

- **2005-2007** احتمال توسعه استاکنکس
- **2008** اولین استفاده در محیط هدف
- **2009** گسترش در تاسیسات نطنز
- **2010 (ژوئن)** کشف توسط شرکت بلاروسی (Kaspersky)
- **(2010 (سپتامبر** تحلیل عمومی توسط کسیرسکی و رسانه‌ها

7.اثر نهایی بر سانتریفیوژها



8.نگاشت بMITRE ATT&CK

- Initial Access
- Execution
- Privilege Escalation
- Persistence
- Defense Evasion
- Credential Access
- Discovery
- Lateral Movement
- Impact (Physical Damage)
- Collection (Limited)

سیستم خبره چیست؟

Expert Systemنوعی سیستم هوشمند مبتنی بر **Artificial Intelligence** است که تلاش می‌کند دانش و تجربه یک متخصص انسانی را شبیه‌سازی کند.

در واقع این سیستم به جای اینکه فقط داده‌ها را ذخیره کند، می‌تواند تحلیل انجام دهد، تصمیم‌گیری کند و نتیجه‌گیری منطقی داشته باشد.

در سیستم خبره، دانش متخصصان در قالب:

Knowledge Base

Security Rules

IF-THEN Rules

ذخیره می‌شود.

سپس سیستم با استفاده از بخشی به نام **Inference Engine** این قوانین را روی داده‌ها اعمال می‌کند.

به زبان ساده، **Expert System**مانند یک کارشناس امنیت عمل می‌کند.

برای مثال اگر تعداد زیادی **Failed Login** در مدت کوتاه مشاهده شود، سیستم می‌تواند تشخیص دهد که احتمال **Brute Force Attack** وجود دارد.

یا اگر حجم **Traffic** به صورت ناگهانی افزایش پیدا کند، سیستم احتمال **DDoS Attack** را بررسی می‌کند.

بنابراین **Expert System** فقط ذخیره‌کننده اطلاعات نیست، بلکه یک سیستم تصمیم‌گیرنده و تحلیل‌گر است.

در حوزه**Cybersecurity** ، سیستم‌های خبره برای:

Threat Detection

Security Analysis

Anomaly Detection

***Incident Response**

کاربرد زیادی دارند.

اجزای سیستم خبره

در این بخش، اجزای اصلی Expert System را بررسی می‌کنیم. یک سیستم خبره برای اینکه بتواند در حوزه Cybersecurity تصمیم‌گیری دقیق انجام دهد، از چند بخش کلیدی تشکیل شده است.

۱) Knowledge Base

اولین و مهم‌ترین بخش، Knowledge Baseیا پایگاه دانش است.

Knowledge Baseمحلی است که در آن تمام دانش امنیتی، تجربه متخصصان و قوانین تشخیص حملات ذخیره می‌شود.

این بخش شامل موارد زیر است:

Security Rules

Attack Signatures

Detection Policies

IF–THEN Rules

برای مثال:

IF Failed Login Attempts > 10 in 1 minute

THEN Brute Force Attack

در واقع Knowledge Base مانند حافظه تخصصی سیستم عمل می‌کند.

۲) Inference Engine

دومین بخش مهم، Inference Engineیا موتور استنتاج است.

Inference Engineوظیفه دارد داده‌های دریافتی را تحلیل کرده و روی آن‌ها تصمیم‌گیری منطقی انجام دهد.

وظایف اصلی آن:

بررسی Rule ها

تطبیق داده با قوانین (Rule Matching)

تحلیل منطقی

نتیجه‌گیری

تصمیم‌گیری امنیتی

به زبان ساده، این بخش «مغز تصمیم‌گیرنده سیستم» است.

۳) Network Database

در این بخش، تمام داده‌های شبکه ذخیره می‌شود، مانند:

Log Files

Network Traffic

Packet Data

User Activity

Security Events

این اطلاعات پایه اصلی تحلیل سیستم هستند و بدون آن‌ها، تشخیص Threat امکان‌پذیر نیست.

۴) Alert System

این بخش مسئول اطلاع‌رسانی در زمان شناسایی Threat است.

Intrusion Detection System در صورت تشخیص رفتار مشکوک، از طریق Alert System اقدام به هشداردهی می‌کند.

روش‌های هشدار:

Dashboard Alert

Email Notification

SMS Alert

Telegram Bot

Real-time Warning

در IPS ها حتی پاسخ خودکار نیز وجود دارد:

Blockکردن IP

قرنطینه سیستم

قطع ارتباط شبکه

۵) User Interface

آخرین بخش، User Interfaceیا رابط کاربری است.

این بخش برای نمایش وضعیت سیستم به مدیر شبکه یا تیم SOC استفاده می‌شود.

در این بخش اطلاعات زیر نمایش داده می‌شود:

وضعیت امنیت شبکه

Alertهای فعال

گزارش حملات

Logهای مهم

نمودارهای ترافیک

نقش هر بخش درCybersecurity

فرض کنید یک مهاجم شروع به Port Scanning می‌کند:

سیستم تعداد زیادی درخواست به**Port** های مختلف را در **Network Traffic** مشاهده می‌کند.

این داده‌ها در **Network Database** ذخیره می‌شوند.

Inference Engineرفتار را تحلیل می‌کند.

Ruleمربوط به **Port Scanning** در **Match, Knowledge Base** می‌شود.

Threatشناسایی می‌شود.

Alert Systemهشدار صادر می‌کند.

نتیجه در **Dashboard** نمایش داده می‌شود.

سوالات:

کدام بخش مهم‌ترین بخش سیستم خبره است؟

Inference Engineمهم‌ترین بخش است، زیرا تمام تحلیل‌ها، تصمیم‌گیری‌ها و تطبیق**Rule** ها در این قسمت انجام می‌شود.

اگر Knowledge Base نباشد چه اتفاقی می‌افتد؟

بدون**Knowledge Base** ، سیستم هیچ **Rule** یا دانشی برای تحلیل ندارد و عملاً نمی‌تواند **Threat**ها را تشخیص دهد.

معماری سیستم

در این پروژه، یک ساختار مبتنی بر Expert System طراحی کردم که هدف آن تحلیل داده‌های شبکه و شناسایی تهدیدات در حوزه Cybersecurity است.

جریان کلی سیستم

در این معماری، داده‌ها به صورت مرحله‌ای پردازش می‌شوند:

۱. ابتدا Network Traffic از شبکه جمع‌آوری می‌شود .

۲. داده‌ها وارد Data Collection Layer می‌شوند .

۳. سپس در Network Database ذخیره می‌شوند .

٤. بعد از آن، Inference Engine داده‌ها را تحلیل می‌کند .

٥. قوانین امنیتی از Knowledge Base بررسی می‌شوند .

٦. در صورت تشخیص تهدید، Threat Detection فعال می‌شود .

۷. در نهایت Alert System هشدار تولید می‌کند .

۱. Network Traffic

در این بخش، تمام Packet ها و ارتباطات شبکه وارد سیستم می‌شوند.

شامل:

- Incoming Traffic
- Outgoing Traffic
- User Requests
- Server Communication

۲. Data Collection Layer

این لایه وظیفه جمع‌آوری داده‌ها از منابع مختلف را دارد.

مانند:

- Packet Capture
- Log Collection
- System Events

۳. Network Database

در این مرحله داده‌ها ذخیره می‌شوند تا برای تحلیل‌های بعدی استفاده شوند.

این داده‌ها شامل:

- Log Files
- Session Data
- IP Addresses
- Connection Records

۴. Inference Engine

Inference Engineدر این مرحله داده‌ها را تحلیل می‌کند و تصمیم‌گیری انجام می‌دهد.

این بخش:

- Rule Matchingانجام می‌دهد
- رفتار شبکه را تحلیل می‌کند
- الگوهای مشکوک را شناسایی می‌کند

۵. Knowledge Base

Knowledge Baseشامل قوانین امنیتی و الگوهای حمله است.

این بخش مرجع تصمیم‌گیری سیستم محسوب می‌شود.

۶. Threat Detection

در این مرحله، سیستم تشخیص می‌دهد که آیا رفتار مشاهده‌شده:

- Normal Behaviorاست
- یا Suspicious Activity
- یا Attack Pattern

۷. Alert System

در صورت تشخیصThreat ، سیستم وارد فاز واکنش می‌شود:

- ارسال Alert
- ثبت Incident
- اطلاع به SOC
- در برخی موارد Block کردن مهاجم

مثال :

فرض کن یک حمله DDoS رخ می‌دهد:

۱. حجم زیادی از Traffic وارد سیستم می‌شود .

۲. Data Collectionآن را ثبت می‌کند .

۳. Inference Engineافزایش غیرعادی Traffic را تشخیص می‌دهد .

٤. Rule, Knowledge Base مربوط به DDoS را Match می‌کند .

۵. Threat Detectionفعال می‌شود .

۶. Alert Systemهشدار صادر می‌کند .

۷. SOCاز طریق Dashboard متوجه حمله می‌شود .

سوالات :

چرا سیستم را به صورت لایه‌ای طراحی کردیم؟

چون معماری لایه‌ای باعث افزایشScalability ، نگهداری آسان‌تر سیستم و باعث جداسازی وظایف (Separation of Concerns)می‌شود و هر بخش به صورت مستقل قابل توسعه است.

پایگاه دانش حملات(Knowledge Base)

Knowledge Baseدر واقع جایی است که تمام قوانین، الگوها و دانش مربوط به حملات سایبری در آن ذخیره می‌شود. این بخش یکی از مهم‌ترین اجزای سیستم در حوزه Cybersecurityمحسوب می‌شود.

در این سیستم، حملات به صورت Rule-Based تعریف می‌شوند، یعنی هر حمله یک الگوی مشخص دارد که به صورت IF–THEN نوشته می‌شود.

نمونه قوانین حملات

1. Brute Force Attack

IF Failed Login Attempts > 10
AND Time < 1 Minute
THEN Brute Force Attack

2. Port Scanning Detection

IF Number of Destination Ports is High
THEN Port Scanning Detected

در اینجا سیستم مثل یک متخصص امنیت عمل می‌کند.

یعنی اگر یک رفتار خاص در شبکه دیده شود، سیستم آن را با قوانین موجود در Knowledge Baseمقایسه می‌کند و اگر مطابقت داشته باشد، نوع حمله را تشخیص می‌دهد.

سوالات:

اگر بخواهیم یک حمله جدید اضافه کنیم، چه کاری باید انجام دهیم؟

باید یک Rule جدید به Knowledge Base اضافه کنیم که رفتار آن حمله را تعریف کند تا Inference Engineبتواند آن را شناسایی کند.

MITRE ATT&CK

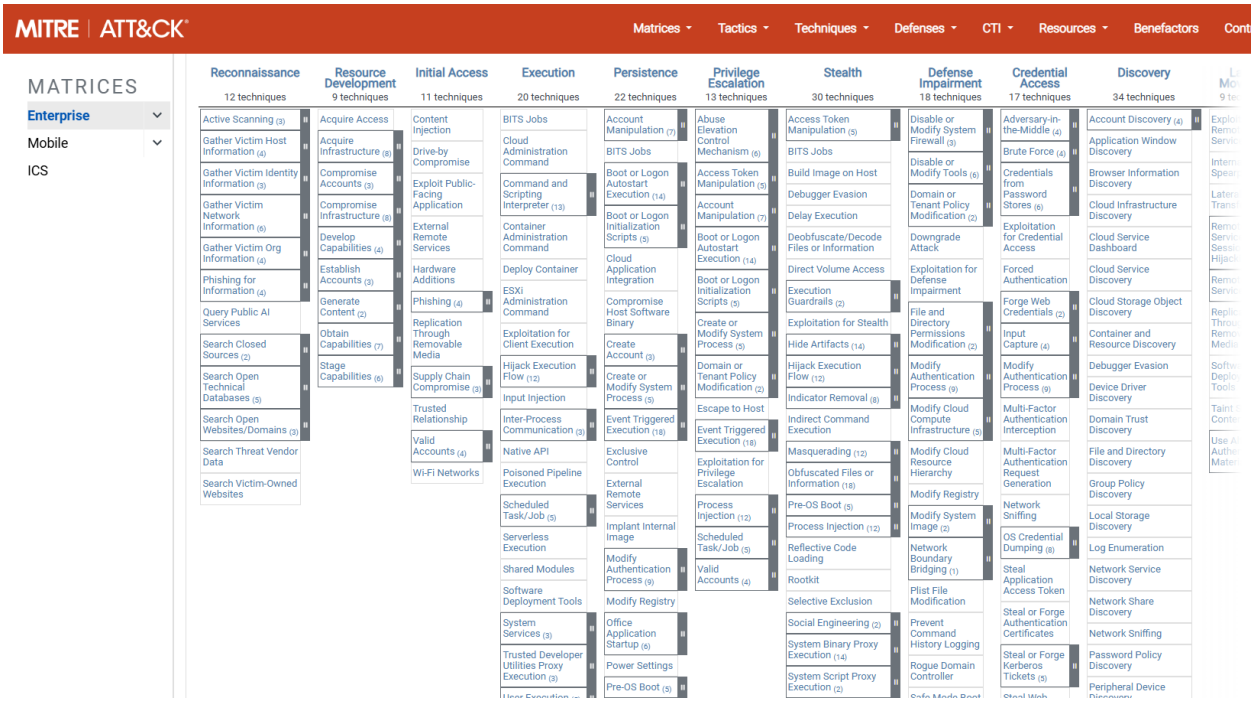
در حوزه امنیت سایبری، پایگاه‌های دانش نقش مهمی در ذخیره، سازمان‌دهی و مدیریت اطلاعات مربوط به تهدیدات، آسیب‌پذیری‌ها و الگوهای حمله ایفا می‌کنند. این پایگاه‌ها با ارائه دانش ساختاریافته، امکان تحلیل بهتر رویدادهای امنیتی، پشتیبانی از تصمیم‌گیری و توسعه سامانه‌های هوشمند تشخیص تهدید را فراهم می‌سازند. یکی از شناخته‌شده‌ترین و پرکاربردترین پایگاه‌های دانش در این حوزه، چارچوب MITRE ATT&CK است که به‌عنوان یک مرجع استاندارد برای مستندسازی و تحلیل رفتار مهاجمان سایبری مورد استفاده قرار می‌گیرد. این چارچوب با ارائه مجموعه‌ای جامع از تاکتیک‌ها، تکنیک‌ها و رویه‌های حمله، امکان درک بهتر رفتار مهاجمان و طراحی راهکارهای دفاعی مؤثر را فراهم می‌کند.

MITRE ATT&CK که توسط MITRE Corporation توسعه یافته است، یک چارچوب دانش‌محور (Knowledge Base) جامع و مبتنی بر شواهد واقعی در حوزه امنیت سایبری محسوب می‌شود که برای مدل‌سازی رفتار مهاجمان در طول چرخه کامل یک حمله طراحی شده است. این چارچوب که مخفف Adversarial Tactics, Techniques, and Common Knowledge است، رفتار مهاجم را در قالب تاکتیک‌ها (Tactics)، تکنیک‌ها (Techniques) و رویه‌ها (Procedures) سازمان‌دهی می‌کند؛ به‌طوری که تاکتیک‌ها اهداف مهاجم مانند نفوذ اولیه، ماندگاری یا سرقت اعتبارنامه‌ها را مشخص می‌کنند، تکنیک‌ها روش‌های دستیابی به این اهداف را توضیح می‌دهند و رویه‌ها نمونه‌های واقعی و اجرایی از حملات گروه‌های مهاجم را ارائه می‌دهند. ATT&CK همچنین چرخه کامل تهدید را از مراحل ابتدایی مانند شناسایی (reconnaissance) و توسعه منابع تا مراحل پیشرفته‌تر شامل اجرای کد (execution)، افزایش سطح دسترسی (privilege escalation)، دور زدن مکانیزم‌های دفاعی، جمع‌آوری داده، حرکت جانبی (lateral movement)، استخراج اطلاعات (exfiltration) و اثرگذاری (impact) پوشش می‌دهد. این چارچوب علاوه بر ماتریس Enterprise، شامل محیط‌های متنوعی مانند Windows، macOS، Linux، زیرساخت‌های ابری، سیستم‌های موبایل (iOS و Android) و حتی سیستم‌های صنعتی (ICS) است و در کنار تکنیک‌ها، اطلاعاتی نظیر منابع داده

(data sources)، گروه‌های مهاجم، نرم‌افزارهای مخرب و مکانیزم‌های کاهش ریسک (mitigations) را نیز ارائه می‌دهد. این ویژگی‌ها باعث شده است ATT&CK به‌عنوان یکی از جامع‌ترین و پرکاربردترین پایگاه‌های دانش رایگان در حوزه تهدیدات سایبری شناخته شود که به‌طور گسترده در ابزارهای امنیتی، سیستم‌های SIEM و فرآیندهای تحلیل تهدید برای تشخیص رفتار مهاجم و مدل‌سازی حملات مورد استفاده قرار می‌گیرد. در کنار این چارچوب، مدل‌هایی مانند Diamond Model و Cyber Kill Chain نیز در برخی سازمان‌ها برای تحلیل چرخه حمله به‌کار می‌روند، اما ATT&CK به دلیل جزئیات بالا، پوشش گسترده و پذیرش صنعتی، به استاندارد غالب در تحلیل رفتار مهاجمان سایبری تبدیل شده است.

تحلیل شکل ۱ :ماتریسMITRE ATT&CK

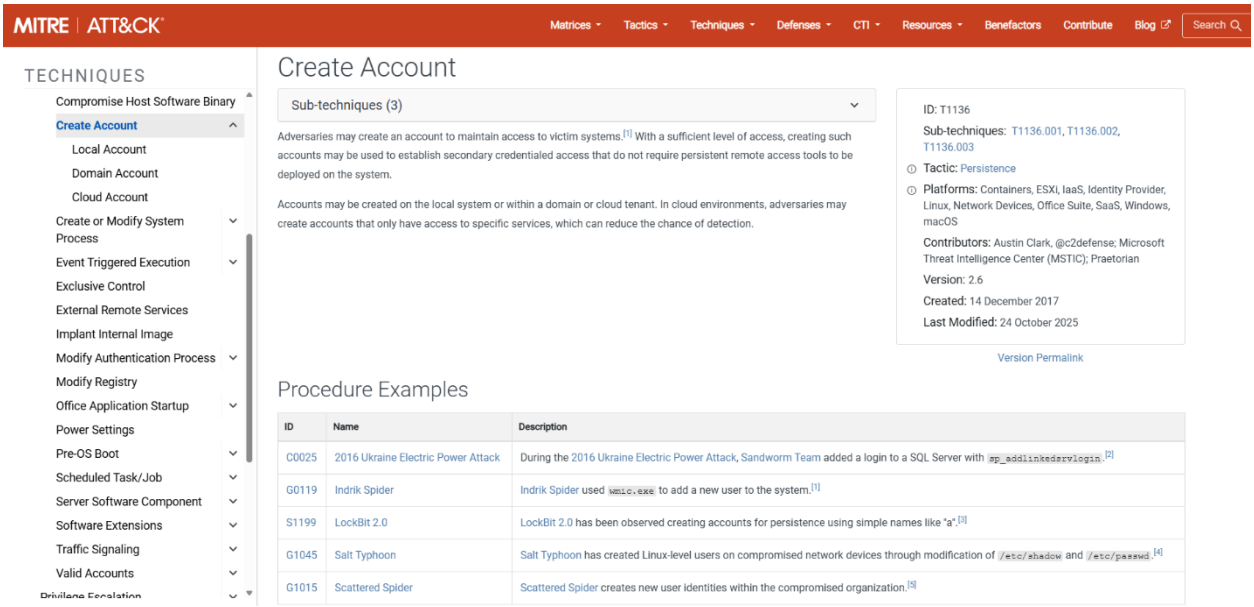
شکل ۱ نمایی از ماتریس Enterprise در چارچوب MITRE ATT&CK را نشان می‌دهد. در این ماتریس، رفتار مهاجمان سایبری بر اساس مراحل مختلف چرخه حمله در قالب تاکتیک‌ها (Tactics) سازمان‌دهی شده است. هر ستون نشان‌دهنده یک هدف یا مرحله از حمله، مانند شناسایی (Reconnaissance)، دسترسی اولیه (Initial Access)، اجرا (Execution)، ماندگاری (Persistence)، افزایش سطح دسترسی (Privilege Escalation)، جمع‌آوری اطلاعات (Collection)، استخراج داده (Exfiltration) و تأثیرگذاری (Impact) است. در زیر هر تاکتیک، مجموعه‌ای از تکنیک‌ها و زیرتکنیک‌ها قرار گرفته‌اند که روش‌های مختلف مورد استفاده مهاجمان برای دستیابی به آن هدف را نمایش می‌دهند. این ساختار سلسله‌مراتبی به تحلیل‌گران امنیتی کمک می‌کند تا فعالیت‌های مشاهده‌شده در شبکه را با الگوهای شناخته‌شده حملات تطبیق داده و فرآیند تشخیص، تحلیل و پاسخ به تهدیدات را بهبود بخشند.



تصویر – ۱

تحلیل شکل ۲: نمونه‌ای از یک تکنیک در MITRE ATT&CK

شکل ۲ جزئیات تکنیک «Create Account» با شناسه T1136 را در پایگاه دانش MITRE ATT&CK نمایش می‌دهد. این تکنیک در تاکتیک Persistence قرار می‌گیرد و به ایجاد حساب‌های کاربری جدید توسط مهاجم به‌منظور حفظ دسترسی به سیستم اشاره دارد. در صفحه مربوط به هر تکنیک، اطلاعات جامعی شامل شناسه تکنیک، تاکتیک مرتبط، پلتفرم‌های تحت تأثیر، زیرتکنیک‌ها، نمونه‌های واقعی استفاده توسط گروه‌های مهاجم، تاریخچه تغییرات و مشارکت‌کنندگان ارائه می‌شود. وجود بخش Procedure Examples نیز نشان می‌دهد که ATT&CK تنها یک مدل نظری نیست، بلکه بر اساس مشاهدات واقعی از حملات و گروه‌های تهدید توسعه یافته است. این ویژگی باعث می‌شود ATT&CK به‌عنوان یک پایگاه دانش عملیاتی و قابل استفاده در سامانه‌های SIEM ، Threat Intelligence و سیستم‌های خبره امنیت سایبری مورد استفاده قرار گیرد.


MITRE | ATT&CK
Matrices
Tactics
Techniques
Defenses
CTI
Resources
Benefactors
Contribute
Blog
Search
TECHNIQUES
Compromise Host Software Binary
Create Account
Local Account
Domain Account
Cloud Account
Create or Modify System Process
Event Triggered Execution
Exclusive Control
External Remote Services
Implant Internal Image
Modify Authentication Process
Modify Registry
Office Application Startup
Power Settings
Pre-OS Boot
Scheduled Task/Job
Server Software Component
Software Extensions
Traffic Signaling
Valid Accounts
Create Account
Sub-techniques (3)
Adversaries may create an account to maintain access to victim systems.[1] With a sufficient level of access, creating such accounts may be used to establish secondary credentialed access that do not require persistent remote access tools to be deployed on the system.
Accounts may be created on the local system or within a domain or cloud tenant. In cloud environments, adversaries may create accounts that only have access to specific services, which can reduce the chance of detection.
ID: T1136
Sub-techniques: T1136.001, T1136.002, T1136.003
Tactic: Persistence
Platforms: Containers, ESXi, IaaS, Identity Provider, Linux, Network Devices, Office Suite, SaaS, Windows, macOS
Contributors: Austin Clark, @c2defense; Microsoft Threat Intelligence Center (MSTIC); Praetorian
Version: 2.6
Created: 14 December 2017
Last Modified: 24 October 2025
Version Permalink
Procedure Examples
ID
Name
Description
C0025
2016 Ukraine Electric Power Attack
During the 2016 Ukraine Electric Power Attack, Sandworm Team added a login to a SQL Server with sp_addlinkedsrvlogin.[2]
G0119
Indrik Spider
Indrik Spider used wmic.exe to add a new user to the system.[1]
S1199
LockBit 2.0
LockBit 2.0 has been observed creating accounts for persistence using simple names like "a".[3]
G1045
Salt Typhoon
Salt Typhoon has created Linux-level users on compromised network devices through modification of /etc/shadow and /etc/passwd.[4]
G1015
Scattered Spider
Scattered Spider creates new user identities within the compromised organization.[5]

تصویر – ۲

موتور استنتاج(Inference Engine)

Inference Engineدر واقع "مغز تصمیم‌گیرنده" سیستم خبره است.

اگر Knowledge Base را حافظه و دانش سیستم در نظر بگیریم، Inference Engineبخشی است که از این دانش استفاده می‌کند تا تحلیل و تصمیم‌گیری انجام دهد.

وظایف اصلیInference Engine

۱ . تحلیل داده‌های شبکه(Network Data Analysis)

اولین وظیفه موتور استنتاج، تحلیل داده‌های شبکه است.

این داده‌ها می‌توانند شامل موارد زیر باشند:

- Network Traffic
- Packet Information
- Security Logs
- User Activity
- System Events

سیستم این اطلاعات را بررسی می‌کند تا رفتارهای مشکوک یا غیرعادی را پیدا کند.

۲. مقایسه داده‌ها با قوانین(Rule Matching)

بعد از دریافت داده‌ها، موتور استنتاج آن‌ها را باRule های موجود در Knowledge Baseمقایسه می‌کند.

برای مثال:

IF Failed Login Attempts > 10
THEN Brute Force Attack

اگر داده‌های واقعی با این Rule مطابقت داشته باشند، سیستم نتیجه می‌گیرد که حمله در حال وقوع است.

۳. تشخیص حملات(Threat Detection)

پس ازRule Matching ، سیستم می‌تواند حملات مختلف را تشخیص دهد، مانند:

- Brute Force Attack
- Port Scanning
- DDoS Attack
- Malware Activity
- Unauthorized Access

در این مرحله سیستم تصمیم می‌گیرد که آیا رفتار مشاهده‌شده Normal است یا Threat محسوب می‌شود.

۴. تصمیم‌گیری امنیتی(Security Decision Making)

یکی از مهم‌ترین ویژگی‌های Inference Engine توانایی تصمیم‌گیری است.

سیستم فقط هشدار نمی‌دهد، بلکه می‌تواند درباره نوع Threat و سطح خطر نیز تصمیم‌گیری کند.

برای مثال:

- Low Risk
- Medium Risk
- High Risk
- Critical Threat

۵. تولید هشدار(Alert Generation)

بعد از تشخیص حمله، سیستم Alert تولید می‌کند.

این هشدار می‌تواند به شکل‌های مختلف ارسال شود:

- **Dashboard Alert**
- **Email Notification**
- **Telegram Alert**
- **SMS**
- **Log Entry**

در برخی موارد حتی سیستم می‌تواند به صورت خودکار واکنش نشان دهد:

- **Block IP**
- **Disconnect Session**
- **Quarantine Device**

در حوزه Cybersecurity، موتور استنتاج باعث می‌شود سیستم بتواند:

- **رفتار شبکه را تحلیل کند**
- **حملات را سریع‌تر تشخیص دهد**
- **خطای انسانی را کاهش دهد**
- **تصمیم‌گیری خودکار انجام دهد**
- **به تیم SOC کمک کند**

برای مثال فرض کنید یک مهاجم شروع به Brute Force روی پنل Login می‌کند.

اتفاقات به این شکل رخ می‌دهد:

۱. **سیستم تعداد زیادی Failed Login مشاهده می‌کند .**

۲. **داده‌ها وارد Inference Engine می‌شوند .**

۳. موتور استنتاج Rule مربوطه را از Knowledge Base بررسی می‌کند .

۴. سیستم نتیجه می‌گیرد که احتمال Brute Force وجود دارد .

۵. Alertتولید می‌شود .

۶. IPمهاجم Block می‌شود .

سوالات:

چرا Inference Engine مهم‌ترین بخش سیستم خبره است؟

زیرا این بخش مسئول تحلیل داده‌ها، بررسیRule ها، تشخیص حملات و تصمیم‌گیری امنیتی است. بدون Inference Engine سیستم فقط مجموعه‌ای از قوانین ذخیره‌شده خواهد بود.

آیا Inference Engine فقط بر اساس Signature کار می‌کند؟

خیر. موتور استنتاج علاوه بر Rule-Based Detection می‌تواند از Behavior Analysis و Anomaly Detectionنیز استفاده کند.

روش‌های استنتاج(Inference Methods)

Inference Engineبرای تحلیل داده‌ها و تصمیم‌گیری از روش‌های مختلف Reasoning* استفاده می‌کند.

دو روش اصلی استنتاج عبارت‌اند از:

- Forward Chaining
- Backward Chaining

۱. Forward Chaining

در روش Forward Chaining حرکت از Result → Data انجام می‌شود.

یعنی سیستم ابتدا داده‌ها وEvent های واقعی را دریافت می‌کند، سپس آن‌ها را باRule های موجود در Knowledge Baseمقایسه می‌کند و در نهایت به نتیجه می‌رسد.

برای مثال فرض کنید سیستم این داده‌ها را مشاهده کند:

- تعداد زیادی Failed Login
- در زمان کوتاه
- از یک IP مشخص

سپس موتور استنتاج Rule مربوطه را بررسی می‌کند:

IF Failed Login Attempts > 10
AND Time < 1 Minute
THEN Brute Force Attack

در نهایت سیستم نتیجه می‌گیرد: Brute Force Attack Detected

ویژگی‌هایForward Chaining

- مبتنی بر داده (Data-Driven): فرآیند استنتاج با دریافت داده‌ها و رویدادهای ورودی آغاز می‌شود.
- تحلیل بلادرنگ (Real-Time Analysis): اطلاعات را هم‌زمان با دریافت آن‌ها بررسی و تحلیل می‌کند.
- مناسب برای پایش مداوم (Continuous Monitoring): برای نظارت دائمی بر شبکه و شناسایی فعالیت‌های مشکوک کاربرد دارد.
- تشخیص سریع تهدیدات (Fast Threat Detection): با بررسی فوری داده‌ها، تهدیدات و حملات احتمالی را در کوتاه‌ترین زمان شناسایی می‌کند.

این روش در SOC Monitoring , SIEM , IPS , IDS بسیار استفاده میشود.

۲. Backward Chaining

در روش Backward Chaining حرکت از Result → Evidence انجام می‌شود.

یعنی سیستم ابتدا یک فرض را در نظر می‌گیرد، سپس به دنبال شواهد می‌گردد تا آن فرض را تأیید یا رد کند.

برای مثال فرض کنید سیستم احتمال دهد که:

DDoS Attack → وجود دارد.

حالا برای اثبات این فرض شروع به بررسی می‌کند:

- حجم Traffic
- تعداد Connection ها
- Logها
- Source IPها

اگر شواهد کافی وجود داشته باشد، حمله تأیید می‌شود.

ویژگی‌های Backward Chaining

- هدف‌محور (Goal-Driven): فرآیند استنتاج از یک نتیجه یا فرضیه شروع می‌شود و برای اثبات یا رد آن به دنبال شواهد و اطلاعات مرتبط می‌گردد.
- مناسب برای تحقیقات امنیتی (Investigation): زمانی کاربرد دارد که یک حادثه یا هشدار امنیتی رخ داده و لازم است علت، منبع و نحوه وقوع آن بررسی شود.
- مناسب برای جرم‌یابی دیجیتال (Digital Forensics): به تحلیل شواهد دیجیتال، لاگ‌ها و آثار به‌جامانده از حملات کمک می‌کند تا جزئیات حادثه مشخص شود.
- تحلیل عمیق‌تر تهدیدها (Deep Threat Analysis): با بررسی دقیق شواهد و ارتباط بین رویدادها، امکان شناسایی ریشه حمله، روش نفوذ و فعالیت‌های مهاجم را فراهم می‌کند.

در حوزه Cybersecurity

- Forward Chainingبیشتر برای Threat Detection لحظه‌ای استفاده می‌شود .
- Backward Chainingبیشتر در Threat Hunting و Incident Investigation* کاربرد دارد .

سوالات:

کدام روش در سیستم‌های امنیتی بیشتر استفاده می‌شود؟

معمولاً Forward Chaining در سیستم‌های Real-Time Monitoring بیشتر استفاده می‌شود، زیرا سریع‌تر Threat ها را شناسایی می‌کند.

Backward Chainingبیشتر در چه حوزه‌ای کاربرد دارد؟

در Threat Hunting ، Digital Forensicsو Incident Investigation استفاده می‌شود، چون سیستم به دنبال شواهد برBای اثبات یک حمله می‌گردد.

شکار تهدیدات(Threat Hunting)

Threat Huntingیکی از مفاهیم پیشرفته در Cybersecurityاست و به معنای جستجوی فعالانه برای پیدا کردن تهدیدات پنهان در شبکه می‌باشد.

در سیستم‌های امنیتی سنتی معمولاً سیستم منتظر می‌ماند تا یک Alert یا Signature مشخص مشاهده شود، اما در Threat Hunting رویکرد کاملاً متفاوت است.

در این روش، تیم امنیت یا سیستم هوشمند به صورت فعال به دنبال:

- Threatهای مخفی
- رفتارهای مشکوک
- فعالیت‌های غیرعادی
- حملات ناشناخته

می‌گردد.

اهدافThreat Hunting

۱. کشف حملات ناشناخته(Unknown Threat Detection)

بسیاری از حملات مدرن مانند:

- Zero-Day Attack
- Advanced Persistent Threat (APT)
- *Fileless Malware

ممکن است توسط ابزارهای معمولی شناسایی نشوند.

Threat Huntingتلاش می‌کند این حملات را قبل از ایجاد خسارت پیدا کند.

۲. شناسایی رفتار مشکوک(Suspicious Behavior Detection)

در این فرآیند فقط Signature بررسی نمی‌شود، بلکه رفتار کاربران و سیستم‌ها نیز تحلیل می‌شود.

برای مثال:

- Loginغیرعادی
- ارتباط با IP ناشناس
- اجرای Process مشکوک
- افزایش غیرطبیعی Traffic

می‌تواند نشانه Threat باشد.

۳. کاهش زمان تشخیص حمله(Reduce Detection Time)

یکی از اهداف مهم Threat Hunting کاهش زمان شناسایی حمله است.

در امنیت سایبری شاخصی به نام(MTTD (Mean Time To Detect وجود دارد.

هرچه Threat سریع‌تر شناسایی شود، خسارت کمتر خواهد بود.

۴. افزایش امنیت شبکه(Improve Network Security)

Threat Huntingباعث می‌شود سازمان:

- دید بهتری نسبت به شبکه داشته باشد
- حملات را زودتر کشف کند
- Incident Responseسریع‌تری انجام دهد
- سطح امنیت را افزایش دهد

تفاوت Threat Hunting با Detection معمولی

Threat Hunting	روش سنتی
Active Search	Passive Detection
جستجوی فعال	وابسته به Alert
مبتنی بر Behavior	مبتنی بر Signature
کشف زودهنگام	واکنش بعد از حمله

سیستم خبره می‌تواند بخشی از فرآیند Threat Hunting را انجام دهد.

سیستم با استفاده از:

- Network Monitoring
- Behavior Analysis
- Rule Matching
- Anomaly Detection

رفتارهای مشکوک را بررسی کرده وThreat های احتمالی را شناسایی می‌کند.

برای مثال فرض کنید یک مهاجم وارد شبکه شده اما هنوز حمله مستقیمی انجام نداده است.

سیستم رفتارهای زیر را مشاهده می‌کند:

- ارتباط با چندین سیستم داخلی
- بررسیPort ها
- ارسال درخواست‌های غیرمعمول
- Loginدر ساعات غیرعادی

هرکدام از این رفتارها شاید به تنهایی خطرناک نباشند، اما در کنار هم می‌توانند نشانه Threat باشند,Threat Hunting این الگوها را پیدا می‌کند.

Threat Huntingیکی از وظایف مهم تیم SOC (Security Operations Center) است.

تحلیلگران SOC با استفاده از:

- SIEM
- Threat Intelligence
- Log Analysis
- Behavioral Analytics

به دنبال تهدیدات مخفی می‌گردند.

سوالات:

Threat Huntingچه تفاوتی با IDS دارد؟

IDSمعمولاً منتظر Signature یا Alert می‌ماند، اما Threat Hunting به صورت فعال به دنبال تهدیدات پنهان و رفتارهای مشکوک می‌گردد.

چرا Threat Hunting اهمیت دارد؟

زیرا بسیاری از حملات مدرن مانند Zero-Day و APT ممکن است توسط ابزارهای سنتی شناسایی نشوند، بنابراین Threat Hunting به کشف زودهنگام این تهدیدات کمک می‌کند.

تشخیص رفتارهای غیرعادی(Anomaly Detection)

Anomaly Detectionیکی از مهم‌ترین قابلیت‌های سیستم‌های امنیتی هوشمند در حوزه Cybersecurity است.

هدف این بخش، شناسایی برخی از رفتارهایی است که با الگوی عادی شبکه تفاوت دارند.

مفهوم اصلیAnomaly Detection

سیستم ابتدا رفتار عادی یا Normal Behavior شبکه را یاد می‌گیرد.

بعد از مشخص شدن الگوی عادی، هر رفتاری که خارج از این الگو باشد به عنوان:

- Suspicious Activity
- Abnormal Behavior
- *Potential Threat

در نظر گرفته می‌شود.

نمونه رفتارهای غیرعادی

۱. افزایش ناگهانی ترافیک(Traffic Spike)

اگر حجم Traffic ناگهان بسیار زیاد شود، ممکن است نشانه:

- DDoS Attack
- Malware Activity
- Data Exfiltration

باشد.

۲. ارسال حجم زیاد داده(Large Data Transfer)

اگر یک سیستم عادی ناگهان حجم زیادی Data ارسال کند، احتمال دارد:

- اطلاعات در حال سرقت باشد
- Backupغیرمجاز انجام شود
- Malwareفعال شده باشد

۳. Login در ساعات غیرعادی

اگر کاربری که همیشه صبح Login می‌کند، ناگهان ساعت ۳ بامداد وارد سیستم شود، این رفتار می‌تواند مشکوک باشد.

۴. ارتباط با IP ناشناس

اتصال به:

- Unknown IP
- Blacklisted IP
- Suspicious Server

ممکن است نشانه ارتباط با Command & Control Server باشد.

۵. دسترسی غیرمجاز کاربران(Unauthorized Access)

اگر یک User به فایل‌ها یا سیستم‌هایی دسترسی پیدا کند که معمولاً به آن‌ها دسترسی ندارد، سیستم این رفتار را غیرعادی تشخیص می‌دهد.

۶. تغییر الگوی رفتاری سیستم

اگر رفتار طبیعی سیستم ناگهان تغییر کند، ممکن است:

- Malware اجرا شده باشد
- سیستم آلوده شده باشد
- مهاجم در حال حرکت در شبکه باشد

یکی از مشکلات روش‌های سنتی امنیتی این است که فقط حملات شناخته‌شده را تشخیص می‌دهند.

اما Anomaly Detectionمی‌تواند حتیThreat هایی را که Signature مشخصی ندارند شناسایی کند.

این موضوع برای مقابله با:

- Zero-Day Attack
- APT
- Insider Threat
- Unknown Malware

بسیار مهم است.

در بسیاری از سیستم‌های مدرن، Anomaly Detectionبا استفاده از:

- Machine Learning
- Behavioral Analytics
- Statistical Analysis

انجام می‌شود.

سیستم به مرور زمان رفتار عادی کاربران و شبکه را یاد می‌گیرد.

برای مثال فرض کنید یک کارمند معمولاً روزانه ۲۰۰ مگابایت Data استفاده می‌کند.

اما ناگهان در نیمه‌شب20گیگابایت Data ارسال می‌شود به یک IP خارجی ناشناس

سیستم این رفتار را غیرعادی تشخیص داده و Alert تولید می‌کند.

Anomaly Detectionیکی از ابزارهای اصلی در Threat Hunting محسوب می‌شود، چون بسیاری از حملات پیشرفته با رفتار غیرعادی شناسایی می‌شوند.

سوالات :

چرا Anomaly Detection اهمیت زیادی دارد؟

زیرا بسیاری از حملات مدرن Signature مشخصی ندارند، اما رفتار آن‌ها غیرعادی است و سیستم می‌تواند از طریق تحلیل رفتار این تهدیدات را شناسایی کند.

آیا Anomaly Detection همیشه دقیق است؟

خیر. ممکن است گاهی False Positive* ایجاد شود، یعنی رفتار عادی به اشتباه مشکوک تشخیص داده شود. به همین دلیل تنظیمThreshold* ها و تحلیل دقیق اهمیت زیادی دارد.

سیستم هشدار سریع(Smart Alert System)

بعد از اینکه Inference Engine یک Threat یا رفتار مشکوک را شناسایی کرد، سیستم باید بتواند به سرعت واکنش نشان دهد.

وظیفه Smart Alert System همین است؛ یعنی اطلاع‌رسانی سریع، ثبت رویداد امنیتی و در برخی موارد انجام واکنش خودکار.

هدف Smart Alert System کاهش زمان پاسخ‌دهی به حملات است.

در امنیت سایبری هر ثانیه اهمیت دارد، چون اگر واکنش دیر انجام شود ممکن است:

- اطلاعات سرقت شود
- Malware گسترش پیدا کند
- سرویس‌ها از دسترس خارج شوند
- خسارت مالی ایجاد شود

انواع عملکردهای سیستم هشدار

۱. ارسال هشدار به مدیر شبکه

اولین وظیفه سیستم، اطلاع‌رسانی سریع به:

- Network Administrator
- SOC Team
- Security Analyst

است.

این هشدار می‌تواند در Dashboard یا پنل مدیریتی نمایش داده شود.

۲. ثبت لاگ امنیتی (Security Logging)

تمام رویدادهای امنیتی در سیستم ذخیره می‌شوند.

این Log ها برای:

- Incident Investigation
- *Digital Forensics
- *Threat Analysis
- *Compliance

بسیار مهم هستند.

۳. ارسال Email Alert

سیستم می‌تواند به صورت خودکار Email ارسال کند تا تیم امنیت سریع‌تر مطلع شود.

مثلاً:

- نوع حمله
- Source IP
- زمان حمله
- *Severity Level

در ایمیل ثبت می‌شود.

۴. ارسال پیام تلگرام

در این پروژه، هشدارها می‌توانند از طریق Telegram Bot نیز ارسال شوند.

این کار باعث می‌شود مدیر شبکه حتی خارج از سازمان هم سریع مطلع شود.

۵. Block کردن IP مهاجم

در برخی شرایط، سیستم می‌تواند به صورت خودکار IP مهاجم را Block کند.

۶. قرنطینه سیستم آلوده(System Quarantine)

اگر سیستم احتمال دهد یک Device آلوده شده است، می‌تواند آن را از شبکه جدا کند تا Threat گسترش پیدا نکند.

بدون سیستم هشدار، حتی اگر حمله شناسایی شود ممکن است تیم امنیت دیر متوجه شود.

تفاوت Alert ساده باSmart Alert

Smart Alert	Alertمعمولی
تحلیل و واکنش	فقط نمایش هشدار
دارایSeverity	بدونSeverity
امکان واکنش خودکار	واکنش دستی

در Security Operations Center، سیستم هشدار یکی از مهم‌ترین بخش‌ها است.

Alertها معمولاً وارد:

- SIEM Dashboard
- SOC Console
- Incident Response Platform

می‌شوند تا توسط تیم امنیت بررسی شوند.

برای مثال فرض کنید سیستم یک Brute Force Attack را شناسایی می‌کند.

اتفاقات به این شکل رخ می‌دهد:

۱. تعداد زیادی Failed Login شناسایی می‌شود .

۲. Inference Engineحمله را تشخیص می‌دهد .

۳. Smart Alert System فعال می‌شود .

۴. پیام هشدار برای Admin ارسال می‌شود .

۵. IPمهاجم Block می‌شود .

۶. Eventدر Security Log ذخیره می‌شود .

نمونهAlert

[ALERT]
Threat Type: Brute Force Attack
Source IP: 192.168.1.15
Risk Level: HIGH
Action Taken: IP Blocked
Time: 10:45 PM

سوالات :

چرا Smart Alert System اهمیت زیادی دارد؟

زیرا تشخیص حمله بدون واکنش سریع کافی نیست. سیستم هشدار باعث می‌شود تیم امنیت سریع‌تر مطلع شده و قبل از گسترش حمله اقدام کند.

آیا سیستم فقط هشدار می‌دهد یا می‌تواند واکنش هم انجام دهد؟

علاوه بر Alert Generation ، سیستم می‌تواند واکنش خودکار مانند IP Blocking یا System Quarantineنیز انجام دهد.

حملات قابل شناسایی(Detectable Cyber Attacks)

در این بخش، انواع Threat ها و حملاتی را بررسی می‌کنیم که توسط Expert System قابل شناسایی هستند.

سیستم با استفاده از:

- Knowledge Base
- Inference Engine
- Network Monitoring
- Behavior Analysis
- Anomaly Detection

می‌تواند الگوهای مختلف حملات سایبری را تشخیص دهد.

۱. Brute Force Attack

در این حمله، مهاجم سعی می‌کند با امتحان کردن تعداد زیادی Password وارد سیستم شود.

نشانه‌های حمله

- تعداد زیاد Failed Login
- تلاش مکرر در زمان کوتاه
- Login Attempts از یک IP مشخص

نحوه تشخیص توسط سیستم

سیستم تعداد Login های ناموفق را بررسی می‌کند و اگر از Threshold مشخصی بیشتر شود، حمله شناسایی می‌شود.

۲. Port Scanning

در این حمله، مهاجمPort های مختلف شبکه را بررسی می‌کند تا سرویس‌های فعال را پیدا کند.

هدف مهاجم

- پیدا کردنService های باز
- شناسایی Vulnerability
- آماده‌سازی برای نفوذ

نشانه‌های حمله

- درخواست به تعداد زیادی Port
- تعداد زیاد Connection Attempt
- رفتار غیرعادی در Network Traffic

۳. DDoS Attack

Distributed Denial of Serviceنوعی حمله است که در آن حجم بسیار زیادی Traffic به سمت سرور ارسال می‌شود تا سرویس از دسترس خارج شود.

نشانه‌های حمله

- افزایش شدید Traffic
- تعداد زیاد Request
- کاهش Performance سرور
- مصرف بالای Bandwidth

نحوه تشخیص

سیستم حجم Traffic را مانیتور کرده و افزایش غیرعادی را شناسایی می‌کند.

۴. Malware Activity

در این حالت سیستم فعالیت‌های مشکوک مربوط به:

- Virus
- Trojan
- Worm
- Ransomware

را شناسایی می‌کند.

رفتارهای مشکوک

- اتصال به IP ناشناس
- اجرای Process غیرمعمول
- تغییر فایل‌ها
- ارسال Data مشکوک

۵. Insider Threat

Insider Threatبه تهدیداتی گفته می‌شود که از داخل سازمان ایجاد می‌شوند.

این Threat می‌تواند توسط:

- کارمند ناراضی
- Userدارای دسترسی
- سوءاستفاده داخلی

ایجاد شود.

نمونه رفتارها

- دسترسی غیرمجاز
- دانلود حجم زیاد Data
- تغییر Permission ها
- استفاده غیرعادی از منابع

۶. Data Exfiltration

در این حمله، مهاجم سعی می‌کند اطلاعات حساس را از شبکه خارج کند.

نمونه داده‌های هدف

- اطلاعات مالی
- Passwordها
- اطلاعات کاربران
- فایل‌های محرمانه

نحوه تشخیص, سیستم موارد زیر را بررسی می‌کند:

- حجم زیاد Data Transfer
- ارتباط با External IP
- انتقال غیرعادی فایل‌ها

این Threat ها جزو رایج‌ترین و خطرناک‌ترین حملات در حوزه Cybersecurity هستند.

شناسایی سریع آن‌ها باعث می‌شود:

- خسارت کاهش پیدا کند
- Incident سریع‌تر کنترل شود

- Data Leak* جلوگیری شود
- Availabilityسیستم حفظ شود

برای مثال فرض کنید یک مهاجم ابتدا Port Scan انجام می‌دهد.

بعد از پیدا کردن سرویس باز:

- Brute Force اجرا می‌کند
- وارد سیستم می‌شود
- Malwareنصب می‌کند
- اطلاعات را سرقت می‌کند

سیستم خبره می‌تواند تمام این مراحل را مرحله‌به‌مرحله شناسایی کند.

سوالات :

آیا سیستم فقط حملات شناخته‌شده را تشخیص می‌دهد؟

خیر. علاوه بر Rule-Based Detection ، سیستم از Behavior Analysis و Anomaly Detectionنیز استفاده می‌کند و می‌تواند برخی Threat های ناشناخته را هم شناسایی کند.

کدام حمله تشخیص سخت‌تری دارد؟

معمولاً Insider Threat و Zero-Day Attack و APT سخت‌تر تشخیص داده می‌شوند، چون رفتار آن‌ها ممکن است شبیه رفتار عادی کاربران باشد.

نمونه لاگ امنیتی(Security Log Sample)

در این بخش یک نمونه خروجی واقعی از سیستم را مشاهده می‌کنیم که نشان می‌دهد چگونه Smart Alert System و Inference Engine نتایج تحلیل خود را به صورت Log امنیتی نمایش می‌دهند.

Logها یکی از مهم‌ترین اجزای سیستم‌های امنیتی در حوزه Cybersecurity هستند، چون تمام رویدادها را برای تحلیل، بررسی و پاسخ‌دهی ثبت می‌کنند.

نمونه خروجی سیستم

```
[WARNING]
Possible Port Scan Detected
Source IP: 192.168.1.10
Target Ports: 1-1024
Time: 10:35 PM
Risk Level: HIGH
```

تحلیل بخش‌های لاگ

۱. WARNING

این بخش نشان می‌دهد که سیستم یک وضعیت مشکوک یا خطر احتمالی را تشخیص داده است، اما هنوز به صورت قطعی تأیید نشده است.

۲. Possible Port Scan Detected

این پیام نشان می‌دهد که سیستم با استفاده از Rule های موجود در Knowledge Base احتمال وقوع حمله Port Scanning را شناسایی کرده است.

۳. Source IP

این بخش آدرس IP مهاجم یا منبع رفتار مشکوک را نشان می‌دهد.

در این مثال IP = 192.168.1.10 سیستم از این اطلاعات برای تحلیل رفتار و ارتباطات شبکه استفاده می‌کند.

۴. Target Ports

این قسمت نشان می‌دهد که مهاجم به چه محدوده‌ای از Port ها دسترسی داشته است . ۱ تا ۱۰۲۴ , این الگو معمولاً نشانه اسکن گسترده پورت‌ها است.

۵. Time

زمان وقوع رویداد بسیار مهم است، چون تحلیل رفتاری (Behavior Analysis) بر اساس بازه زمانی انجام می‌شود.

۶. Risk Level

سیستم بر اساس تحلیل داده‌ها یک سطح ریسک تعیین می‌کند:

- LOW
- MEDIUM
- HIGH
- CRITICAL

در اینجا سطح خطر HIGH است، یعنی نیاز به واکنش فوری وجود دارد.

Logها در سیستم خبره چند کاربرد مهم دارند:

- ثبت رویدادهای امنیتی
- کمک به تحلیل حملات
- بررسی تاریخچه رفتار شبکه
- استفاده در Incident Response

- استفاده در **Threat Hunting**

سوالات :

چرا Log ها در امنیت سایبری مهم هستند؟

زیرا Log ها تمام فعالیت‌های سیستم را ثبت می‌کنند و برای تحلیل حملات، بررسی رخدادها و انجام Digital Forensics ضروری هستند.

Risk Level چگونه تعیین می‌شود؟

بر اساس شدت رفتار مشکوک، تعداد رخدادها، نوع حمله و قوانین موجود در Knowledge Base ، سیستم یک سطح ریسک برای هر Threat تعیین می‌کند.

مزایای سیستم(Advantages of the System)

در این بخش ، مزایای اصلی طراحی این سیستم خبره در حوزه Cybersecurityرا بررسی می‌کنیم.

هدف از پیاده‌سازی این سیستم، افزایش دقت در تشخیص تهدیدات، کاهش زمان پاسخ‌دهی و بهبود سطح کلی امنیت شبکه است.

۱. شناسایی سریع تهدیدات(Fast Threat Detection)

یکی از مهم‌ترین مزایای سیستم، توانایی شناسایی سریع حملات است.

با استفاده ازInference Engine و Anomaly Detection سیستم می‌تواند در لحظه رفتارهای مشکوک را تشخیص دهد.

۲. کاهش خطای انسانی(Reduced Human Error)

در سیستم‌های سنتی، تحلیل لاگ‌ها و تشخیص حملات توسط انسان انجام می‌شود که ممکن است خطا داشته باشد.

اما در این سیستم:

- تصمیم‌گیری مبتنی بر Rule است
- تحلیل داده‌ها خودکار انجام می‌شود
- احتمال خطای انسانی کاهش می‌یابد

۳. تحلیل هوشمند رفتار شبکه(Intelligent Network Behavior Analysis)

سیستم به جای بررسی ساده داده‌ها، رفتار کلی شبکه را تحلیل می‌کند.

این تحلیل شامل:

- الگوهای ترافیک

- رفتار کاربران
- تغییرات غیرعادی
- ارتباطات مشکوک

است.

۴. افزایش سرعت پاسخ به حملات(Faster Incident Response)

وقتی یک Threat شناسایی می‌شود، سیستم بلافاصله واکنش نشان می‌دهد.

این واکنش می‌تواند شامل:

- Alert Generation
- IP Blocking
- Log Registration
- Notification to SOC

باشد.

۵. قابلیت توسعه و ارتقا(Scalability & Extensibility)

این سیستم به صورت ماژولار طراحی شده است، بنابراین می‌توان آن را توسعه داد.

مثلاً اضافه کردن:

- Machine Learning Models
- Threat Intelligence Feeds
- SIEM Integration
- Advanced Analytics

۶. کمک به تیمSOC

در مراکز امنیتی مانند Security Operations Center، حجم داده‌ها بسیار زیاد است.

این سیستم به SOC کمک می‌کند تا:

- سریع‌تر Threat ها را بررسی کنند
- Alertهای مهم را اولویت‌بندی کنند
- تحلیل دقیق‌تری انجام دهند

۷. کاهش خسارت‌های امنیتی(Reduced Security Damage)

هرچه Threat سریع‌تر شناسایی شود، خسارت کمتر خواهد بود.

این سیستم با:

- Real-Time Detection
- Automated Response
- Early Warning System

باعث کاهش:

- Data Breach
- Financial Loss
- System Downtime

می‌شود.

سوالات :

مهم‌ترین مزیت این سیستم چیست؟

مهم‌ترین مزیت، تشخیص سریع و هوشمند تهدیدات در لحظه و کاهش زمان پاسخ‌دهی به حملات است.

آیا این سیستم جایگزین تیم امنیت می‌شود؟

خیر. این سیستم نقش کمک‌کننده دارد و به تیم SOC کمک می‌کند تصمیم‌گیری سریع‌تر و دقیق‌تر انجام دهد، اما جایگزین کامل انسان نیست.

محدودیت‌ها(Limitations)

در این بخش، محدودیت‌ها و چالش‌های سیستم خبره در حوزه Cybersecurityرا بررسی می‌کنیم.

هر سیستم هوشمند در کنار مزایا، دارای محدودیت‌هایی است که باید در طراحی و پیاده‌سازی در نظر گرفته شود.

۱. احتمال False Positive

یکی از مهم‌ترین محدودیت‌ها، ایجاد هشدارهای اشتباه است.

در این حالت سیستم یک رفتار عادی را به اشتباه به عنوان تهدید شناسایی می‌کند.

مثلاً:

- یک کاربر عادی حجم زیادی Data ارسال می‌کند
- سیستم آن را به عنوان Attack تشخیص می‌دهد

این موضوع باعث افزایش بار کاری تیم SOC می‌شود.

۲. نیاز به بروزرسانی قوانین(Rule Updates)

سیستم Knowledge Base است، بنابراین قوانین باید به طور مداوم به‌روز شوند.

در غیر این صورت:

- حملات جدید شناسایی نمی‌شوند
- دقت سیستم کاهش پیدا می‌کند
- سیستم قدیمی و ناکارآمد می‌شود

۳. پیچیدگی حملات Zero-Day

حملات Zero-Day Vulnerabilityاز بزرگ‌ترین چالش‌ها هستند.

این حملات:

- Signatureندارند
- قبلاً دیده نشده‌اند
- رفتار آن‌ها ناشناخته است

بنابراین تشخیص آن‌ها برای سیستم‌های Rule-Based سخت است.

۳. مصرف منابع سیستم(Resource Consumption)

سیستم برای تحلیل Network Traffic , Logs و Packet Data نیاز به منابع پردازشی دارد.

اگر حجم شبکه زیاد باشد، ممکن است عملکرد سیستم کاهش یابد.

۵. نیاز به مانیتورینگ مداوم

این سیستم باید به صورت ۷/۲۴ فعال باشد.

زیرا حملات سایبری در هر زمان ممکن است رخ دهند و معمولاً بدون هشدار قبلی شروع می‌شوند بنابراین سیستم نیاز به Monitoring دائمی دارد.

سوالات :

چرا False Positive مشکل مهمی است؟

چون باعث می‌شود سیستم هشدارهای اشتباه تولید کند و تیم امنیت وقت و منابع خود را برای بررسی موارد غیرواقعی صرف کند.

چگونه می‌توان محدودیت‌های سیستم را کاهش داد؟

با استفاده ازMachine Learning ، تحلیل رفتاری پیشرفته، و Threat Intelligence می‌توان دقت سیستم را افزایش داد و False Positive را کاهش داد.

نتیجه‌گیری(Conclusion)

در حوزه **Cybersecurity**، استفاده از سیستم‌های هوشمند و مبتنی بر دانش نقش بسیار مهمی در افزایش سطح امنیت شبکه دارد.

در این پروژه، یک سیستم مبتنی بر **Expert System** بررسی شد که با استفاده از سه بخش اصلی کار می‌کند:

- **Knowledge Base**
- **Inference Engine**
- **Network Behavior Analysis**

این سیستم قادر است:

- تهدیدات سایبری را سریع شناسایی کند
- حملات شبکه را تشخیص دهد
- رفتارهای غیرعادی را تحلیل کند
- بر اساس قوانین تصمیم‌گیری کند

استفاده از این نوع سیستم‌ها باعث می‌شود:

- سرعت شناسایی حملات افزایش یابد
- دقت تشخیص بهبود پیدا کند
- خطای انسانی کاهش یابد
- خسارات ناشی از حملات کمتر شود

این نوع سیستم‌ها در محیط‌های واقعی مانند:

- Security Operations Center
- SIEM Systems
- IDS/IPS Platforms

به عنوان بخش مهمی از زیرساخت امنیتی استفاده می‌شوند.

در نهایت می‌توان گفت این پروژه نشان می‌دهد که سیستم‌های خبره می‌توانند با ترکیب دانش متخصصان امنیت و تحلیل هوشمند داده‌ها، نقش مؤثری در شناسایی سریع تهدیدات و افزایش امنیت سایبری داشته باشند.

نمونه‌های معروف سیستم‌های خبره و هوشمند در امنیت سایبری:

- Splunk Enterprise Security
- IBM QRadar
- SIEM
- Microsoft Sentinel
- Cloud-based SIEM with AI and Threat Intelligence
- Darktrace
- Palo Alto Networks Cortex XDR
- Cisco SecureX
- CrowdStrike Falcon
- Rapid7 InsightIDR
- SIEM + UEBA + Threat Detection
- Elastic Security
- FireEye Helix
- Incident Investigationو Threat Intelligence

این سیستم‌ها معمولاً از ترکیب فناوری‌های زیر استفاده می‌کنند:

SIEM

Machine Learning

UEBA

Threat Intelligence

Automated Response

Behavioral Analysis

واژه‌نامه مفاهیم تخصصی امنیت سایبری

Vulnerability : آسیب‌پذیری یا ضعف امنیتی در سیستم، نرم‌افزار یا شبکه که مهاجم می‌تواند از آن سوءاستفاده کند.

Exploit : کد، ابزار یا روشی که برای سوءاستفاده از یک **Vulnerability** استفاده می‌شود.

NSA : سازمان امنیت ملی آمریکا که در زمینه اطلاعات، رمزنگاری و عملیات سایبری فعالیت می‌کند.

Remote Code Execution : نوعی آسیب‌پذیری که به مهاجم اجازه می‌دهد از راه دور روی سیستم قربانی کد اجرا کند.

SMB Vulnerability Fix : به‌روزرسانی یا **Patch** امنیتی برای رفع آسیب‌پذیری‌های پروتکل **SMB** در ویندوز.

Sandbox : محیط ایزوله و کنترل‌شده برای اجرای فایل‌ها یا برنامه‌های مشکوک بدون آسیب به سیستم اصلی

False Positive : تشخیص اشتباه یک فعالیت سالم به عنوان تهدید یا حمله

Threshold : حد یا مقدار تعیین‌شده برای فعال شدن **Alert** یا تشخیص رفتار مشکوک.

Severity : میزان شدت یا اهمیت یک تهدید، آسیب‌پذیری یا رخداد امنیتی.

Reconnaissance : مرحله جمع‌آوری اطلاعات درباره هدف قبل از انجام حمله سایبری.

Correlation : تحلیل و ارتباط دادن چند **Event** یا **Log** مختلف برای شناسایی حملات و الگوهای مشکوک.

Cyber Warfare : به مجموعه عملیات‌های تهاجمی و دفاعی در فضای سایبری گفته می‌شود که با اهداف نظامی، سیاسی یا راهبردی توسط دولت‌ها یا گروه‌های وابسته به آن‌ها علیه زیرساخت‌ها، سامانه‌ها و اطلاعات طرف مقابل انجام می‌شود.

Incident : Incident یا رخداد امنیتی به هر رویدادی گفته می‌شود که امنیت، محرمانگی (Confidentiality)، یکپارچگی (Integrity) یا دسترس‌پذیری (Availability) اطلاعات و سیستم‌ها را تهدید کند یا نقض نماید.

Reasoning : در یک سیستم خبره امنیت سایبری، Reasoning به فرآیندی گفته می‌شود که در آن سیستم با استفاده از داده‌های ورودی (لاگ‌ها، رویدادها، ترافیک شبکه) ، پایگاه دانش (Knowledge Base) و قوانین امنیتی (Rules) نتیجه‌گیری می‌کند که یک رویداد عادی (Normal) است، مشکوک (Suspicious) است یا یک حمله (Attack) محسوب می‌شود.

Incident Investigation : بررسی و تحلیل یک حادثه امنیتی پس از وقوع آن برای فهمیدن علت، نحوه رخ دادن و میزان خسارت آن.

Fileless Malware : نوعی بدافزار است که روی هارد دیسک فایل ذخیره نمی‌کند و مستقیم در حافظه RAMاجرا می‌شود ،از ابزارهای معتبر سیستم مثل PowerShell، WMI،Registry برای اجرای حمله استفاده می‌کند.

Potential Threat : (تهدید بالقوه) به شرایط، رفتارها یا نشانه‌هایی گفته می‌شود که نشان می‌دهد ممکن است یک حمله یا آسیب امنیتی در آینده رخ دهد، اما هنوز به‌صورت قطعی اتفاق نیفتاده است.

Data Exfiltration : استخراج یا سرقت داده فرآیندی است که در آن مهاجم به‌صورت غیرمجاز داده‌ها را از یک سیستم یا شبکه خارج کرده و به یک مقصد خارجی منتقل می‌کند.

Digital Forensics : جمع‌آوری، حفظ و تحلیل شواهد دیجیتال (مثل فایل‌ها، لاگ‌ها و حافظه سیستم) برای کشف فعالیت‌های مخرب و استفاده در تحقیقات یا مسائل قانونی.

Threat Analysis : تحلیل تهدیدات سایبری، رفتار مهاجمان، بدافزارها و تکنیک‌های حمله برای شناسایی ریسک‌ها و جلوگیری از حملات آینده.

Compliance : رعایت استانداردها، قوانین و سیاست‌های امنیتی سازمان یا دولت برای حفظ امنیت اطلاعات و جلوگیری از نقض مقررات.

Data Leak: (نشت داده) به حالتی گفته می‌شود که اطلاعات حساس، محرمانه یا مهم یک سازمان، شرکت یا فرد بدون مجوز در اختیار افراد غیرمجاز قرار بگیرد.